BLUE TEAM / SOC

Wazuh SIEM مشروع مختبر

لغة المستند: العربية — Technical terms in English

جدول المحتويات

نظرة عامة على الأقسام الرئيسية

القسم	الصفحة	القسم	الصفحة
1. ملف المشروع	–	11. النتائج والقيود والدروس المستفادة	–
2. البنية وتدفق البيانات	–	12. بنية Portfolio للتقدم إلى الوظائف	–
3. بنية منصة Monitoring	–	13. خارطة طريق التطوير	–
4. حالات استخدام Detection	–	14. سجل الأدلة	–
5. مراقبة Endpoint	–	15. Detection Engineering باستخدام Sysmon وSigma وSuricata	–
6. مراقبة Active Directory	–	16. دراسة حالة SOC: فحص TCP SYN باستخدام Suricata	–
7. هندسة Detection: فحص الشبكة	–	17. دراسة حالة SOC: Encoded PowerShell	–
8. تقوية Ubuntu وقبول المخاطر	–	18. دراسة حالة SOC: الحسابات والمجموعات ذات الامتيازات	–
9. Sysmon وEncoded PowerShell	–	19. نظرة عامة على Dashboards وطريقة العرض	–
10. Alert Triage وIncident Response	–	20. MITRE ATT&CK وأنواع Events	–

1. ملف المشروع

ما الذي تم بناؤه وما هي الفوائد العملية التي يبرهن عليها المشروع

وصف قصير

في بيئة مختبرية معزولة تعتمد Hyper-V، تم إنشاء Blue Team Stack مركزي باستخدام Wazuh. ترسل أنظمة Windows Server 2022 وWindows 11 وUbuntu الأحداث الأمنية إلى Wazuh Manager على CentOS. ويُستخدم Kali Linux حصراً كنظام اختبار مصرح به. يجمع المشروع بين Telemetry على Windows وLinux، وSysmon، وSigma Rules، وبيانات شبكة Suricata، مع إجراءات Detection وTriage وIncident Response قابلة للتكرار.

نتائج في لمحة

الأدلة	نتيجة
ثلاث صفحات نشطة agents; البحث والتحليل في Wazuh Dashboard	عرض مركزي لـ Windows و Linux events
تمت إضافة الملف وتعديله وحذفه ؛ تغيير المحتوى عبر syscheck.diff	عبر منصة FIM
Event IDs 4625 و 4720 و 4728 و 4729 و 4726	Windowsity ورصد AD
Rules 100110 و 100111; مرتبط level 10 alert; MITRE T1046	تملك scan detection
Sysmon Event ID 1; Wazuh rule 92057; level 12; MITRE T1059.001	Sysmon/PowerShell detection
علاج مع قبل/After-Nachweis ومبرر استثناء Ubuntu	SCA و Risk Acceptance
Triage, تصنيف, runbooks, التنظيف والفحص النهائي	التحرير الموجه نحو الحوادث
whoami /priv; Sigma CLI مع 0 بناء الجملة وأخطاء الشرط	التنمية Sigma rule
TCP-SYN; Rule 100121, Level 8, MITRE T1046 و ICMP	detection الشبكة Suricata

الكفاءات المثبتة

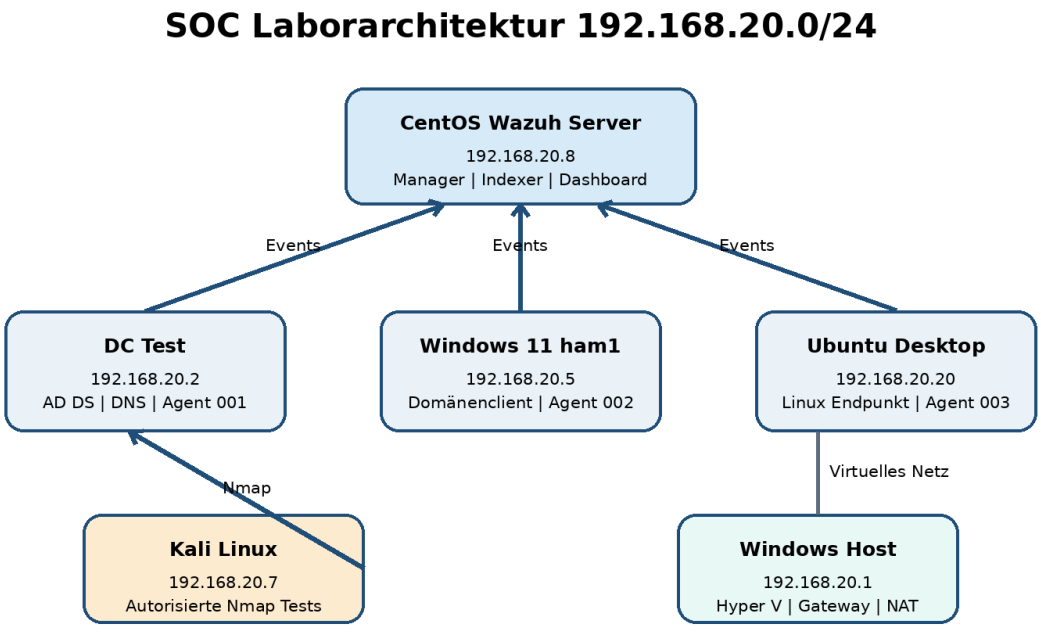
- SIEM العملية الأساسية: تحقق من agents, managers, indexers, dashboards و logs مصادر.
- Detection Engineering: تحليل detection gap, تطوير rules, اختبار الارتباط وتعيين MITRE techniques.
- Alert Triage: تقييم مشترك agent, المستخدم, المصدر, الوقت, rule ID, level ومتابعة النشاط.
- Windows مراقبة الأمن: Active Directory, PowerShell, Sysmon و Windows Event Logs.
- Linux مراقبة الأمن: تقييم من الناحية الفنية PAM, FIM وCIS-نتائج مقرها SCA.
- الوثائق: تتبع النتائج والقيود والتنظيف و risk acceptance.

2. البنية وتدفق البيانات

بيئة مختبرية صغيرة ومحددة بوضوح مع أدوار نظام قابلة للتكرار

الأنظمة والأدوار

نظام	عنوان IP	الدور	Wazuh
المضيف Windows	192.168.20.1	Hyper-V, بوابة, NAT	agent لا
DC-Test	192.168.20.2	Windows Server 2022, AD DS, DNS, IIS	Agent 001
ham1	192.168.20.5	Windows 11 client, Sysmonالمجال	Agent 002 غير صالح
ubuntu-Desktop	192.168.20.20	Ubuntu Desktop, FIM, PAM, SCA	Agent 003 غير صالح
Kali Linux	192.168.20.7	الاختبارات المعتمدة	agent لا
الخادم Wazuh	192.168.20.8	Manager, indexer, dashboard	خادم محلي



الشكل 1: الهندسة المعمارية وتدفق البيانات من بيئة المختبر *SOC*

تدفق البيانات

ترسل أجهزة Endpoint الأحداث إلى Wazuh Manager، حيث تُفك ترميز البيانات وتُقيّم باستخدام Rules القياسية والمحلية، ثم تُخزّن في Indexer. ويعرض Dashboard التنبيهات لإجراء البحث والتصفية والتحليل.

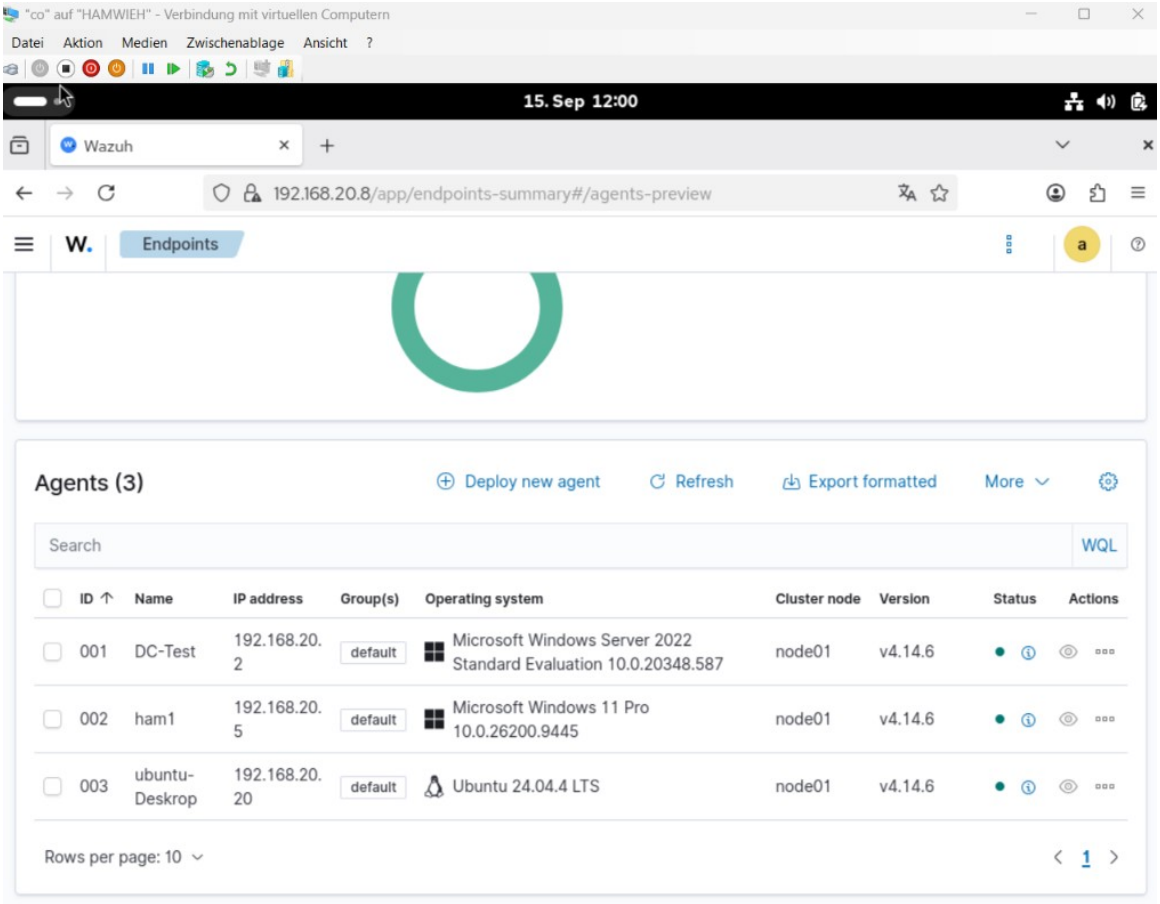
الاختبارات الحدية المختبرية حصرا في شبكة المختبرات الداخلية؛ لا توجد أنظمة خارجية.

3. بنية منصة Monitoring

من التشغيل الأساسي إلى سلسلة التحقق من events

مكونات Wazuh

CentOS Wazuh Manager, Indexer و Dashboard. DC-Test, ham1 و ubuntu-Desktop تم تسجيلها ك agents.
اقتصر جمع البيانات على المصادر ذات الصلة للحفاظ على التحليل واضح.



الشكل 2: ثلاثة نشط Wazuh Agents مع associated endpoints

ضمان الجودة

- تم تشغيل كل use case بطريقة متحكم فيها وتم فحصها لأول مرة محليًا ، ثم في SIEM.
- لكل ناجحة alert, على الأقل agent, event أو rule ID, level والسياق تم التحكم.
- تم التحقق من صحة rules الخاصة قبل إعادة التشغيل.
- تم حذف الحسابات المؤقتة والتغييرات المميزة بعد الاختبار وإعادة فحصها.
- تم فحص المفقودين alerts بشكل منفصل بعد التدقيق والنقل وفك التشفير واللوائح.

4. حالات استخدام Detection

اختبار events, rules وتقييم المحلل

Use Case	مصدر البيانات	Detection	التقييم
Ubuntu FIM غير صالح	Wazuh FIM غير صالح	Rules 554, 550, 553; syscheck.diff	وُفِيَ
Ubuntu مصادقة	PAM / auth logs	Rule 5503, Level 5	وُفِيَ
Windows التسجيل	Log الأمان	Event 4625 / Rule 60122, level 5	وُفِيَ
PowerShell كتلة سكربت	PowerShell التشغيلية	Event 4104 غير صالح	وُفِيَ
AD دورة حياة حساب	Log الأمان	4720, 4728, 4729, 4726	وُفِيَ
مجموعة الامتياز	Log الأمان	Rule 60159 غير صالح	وُفِيَ
Scan الشبكة	Windows منصة تصفية	100110 100111, level 10, T1046	وُفِيَ
Ubuntu SCA غير صالح	Wazuh SCA غير صالح	تحقق 35517 مرت؛ 35509 موثقة استثناء	تم مراجعته
Sysmon PowerShell غير صالح	Sysmon Event ID 1 غير صالح	Rule 92057, level 12, T1059.001	وُفِيَ
Sysmon امتياز Discovery	Sysmon Event ID 1 غير صالح	Rule 100120; مخصص whoami /priv	وُفِيَ
Suricata ICMP غير صالح	eve.json / SID 1000001	Wazuh Rule 86601 غير صالح	وُفِيَ
Suricata TCP SYN Scan غير صالح	eve.json / SID 1000002	Rule 100121, Level 8, T1046	وُفِيَ

مبدأ التقييم

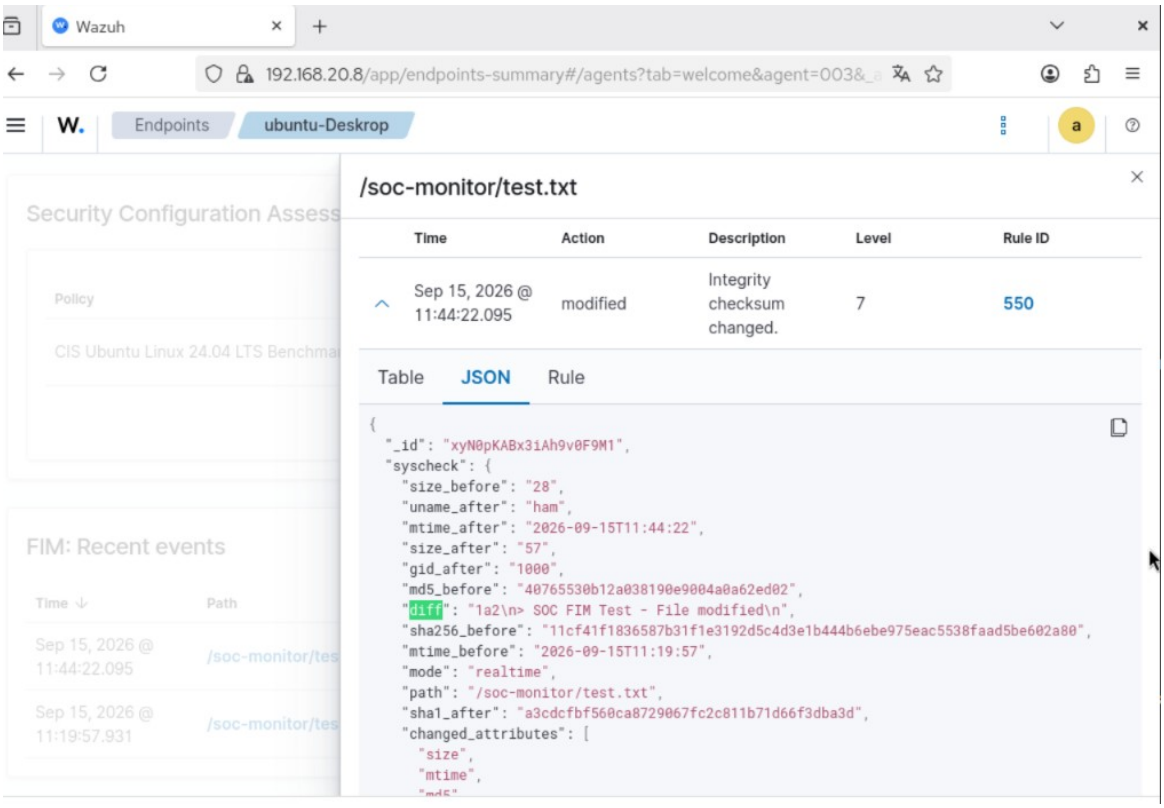
event هو سجل تقني فقط. يظهر alert أنه تم تشغيل rule. فقط triage يقرر ما إذا كان الحادث ينشأ منه. لذلك ، لم يكن alert level أبداً considered فقط ، ولكن أيضًا المصدر والمستخدم والوقت والتفويض والنشاط اللاحق.

5. مراقبة Endpoint

تغييرات الملفات والتسجيلات و PowerShellity

مراقبة سلامة الملفات

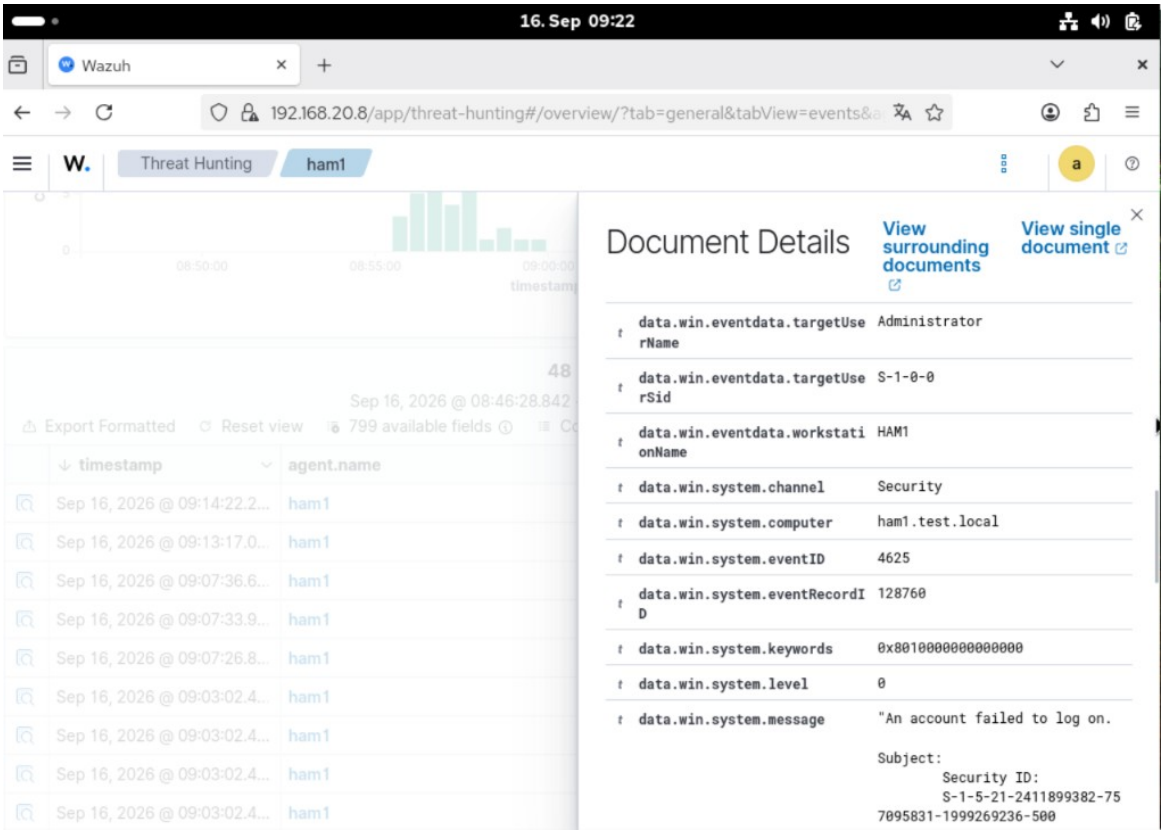
تم إعداد FIM لمسارات محددة في Ubuntu و Windows 11. تم إنشاء الملفات وتعديلها وحذفها في اختبارات خاضعة للرقابة. أظهر Wazuh الإجراءات المضافة والمعدلة والمحذوفة ؛ بالإضافة إلى ذلك ، كان المحتوى مفهومًا عبر syscheck.diff. تم اختيار المسارات بشكل ضيق عمدا بحيث لم يكن هناك حجم event غير ضروري.



الشكل 3: عرض تفاصيل *FIM* مع تغيير موثق للمحتوى إلى *Ubuntu*

فشل تطبيق Windows

فشلت محاولة login على Wazuh. Windowsed loged event IDed 4625. تولى مجموعة البيانات ك rule ham1. على 60122 level 5. المستخدمون وعنوان المصدر و login نوع وتواتر.infirectin



الشكل 4: *دليل على Wazuh Windows event 4625 في ham1*

PowerShell Script Block Logging غير صالح

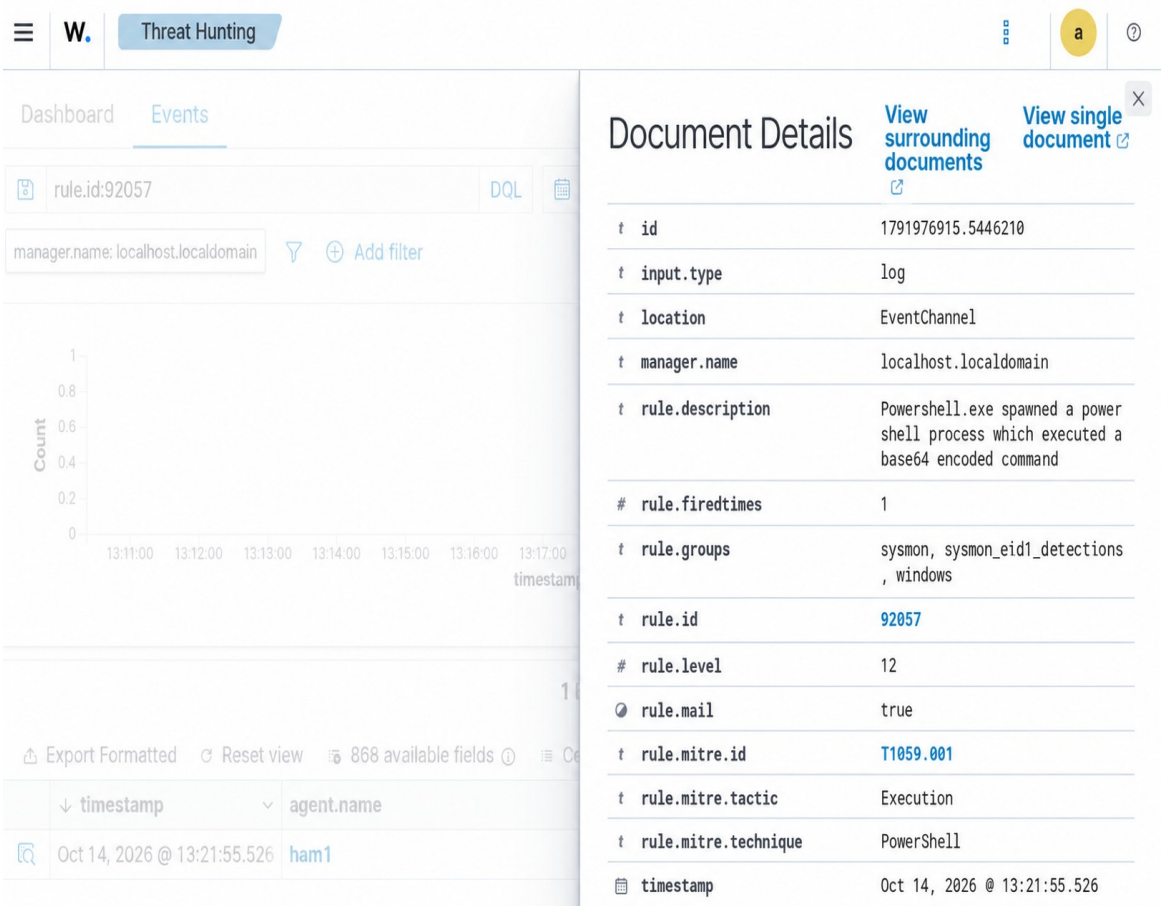
اختبار التحكم ولدت PowerShell Event ID 4104. هو أيضا أداة الإدارة ومسار الهجوم ممكن. وبالتالي، فإن Event ID وحدها ليست كافية لقرار الحادث. المحتوى، سياق المستخدم، الأم process وغيرها events يجب تقييم معا.

6. مراقبة Active Directory

التعرف على التغييرات المميزة وتنظيفها بالكامل

تم إنشاء حساب مؤقت على DC-Test ، تمت إضافته إلى Domain Admins ، تمت إزالته وحذفه بعد ذلك. Events 4720 و 4728 و 4729 و 4726 تمثل دورة الحياة. تم تسليط الضوء على تغيير المجموعة المتميزة بواسطة Rule 60159.

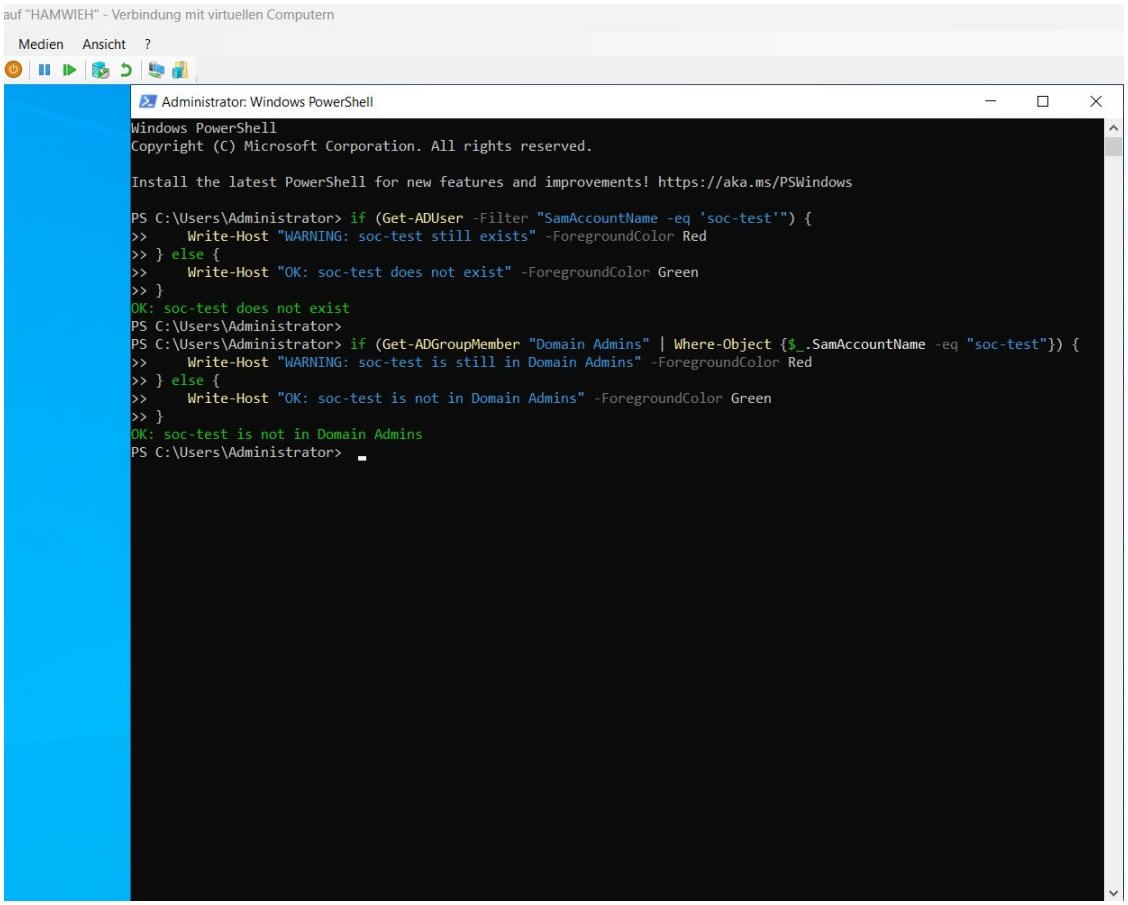
خطوة	Windows Event غير صالح	سؤال المحلل
الحساب الذي تم إنشاؤه	4720	من الذي أنشأ الحساب متى؟
تمت إضافته إلى Domain Admins	4728	هل كان هناك تغيير معتمد؟
تمت إزالتها من Domain Admins	4729	هل انتهت العضوية المميزة بالكامل؟
الحساب حذف	4726	هل ترك أعضاء المجموعة أو غيرها من القطع الأثرية وراء؟



الشكل 5: *Wazuh rule 60159* للتغيير في *Domain Admins*

التحكم النهائي

بعد الاختبار ، تم التحقق من أن الحساب المؤقت لم يعد موجودًا وأنه لا توجد عضوية في Domain Admins بقايا. وهكذا ، ليس فقط detection ولكن أيضا ثبت التنظيف الآمن.



الشكل 6: التحكم النهائي في حساب اختبار *AD* عن بعد

7. هندسة Detection: فحص الشبكة

raw event من detection المرتبطة إلى

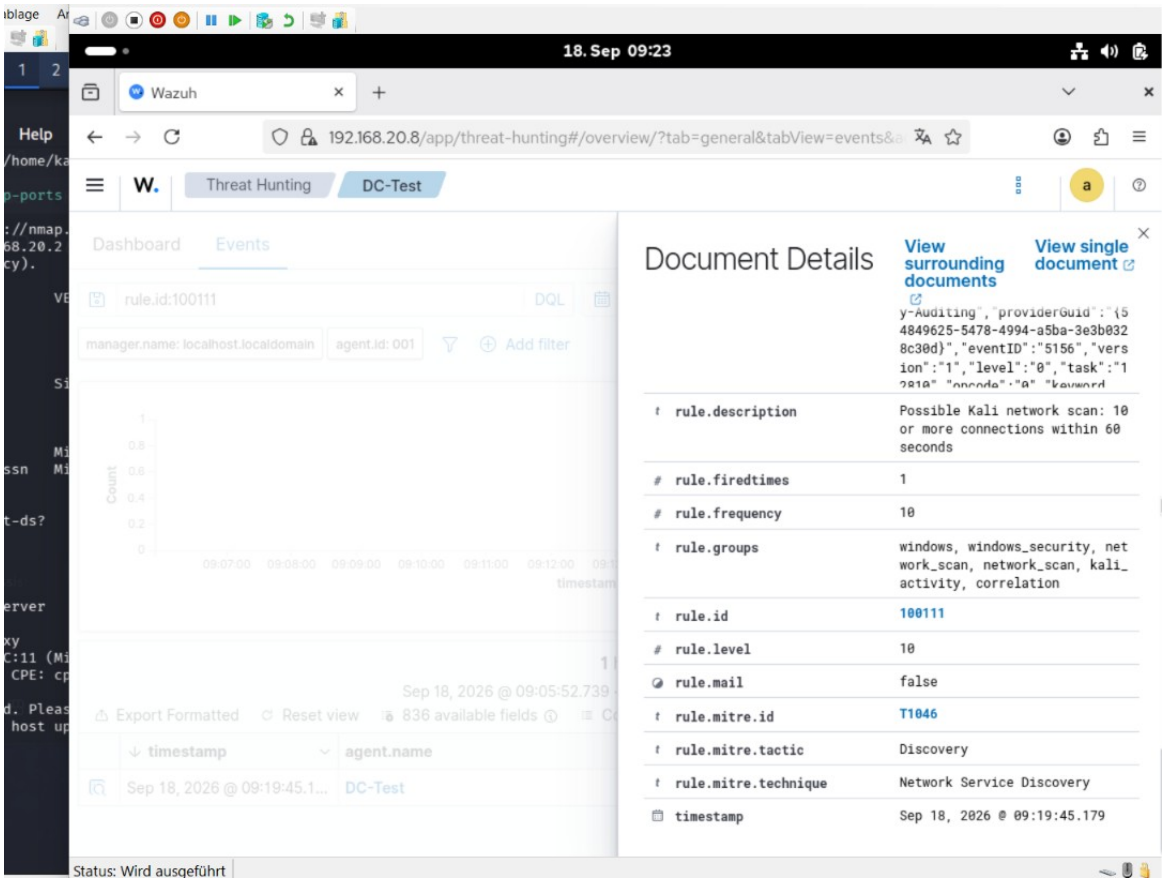
موقف البداية و detection gap

اختبار محدود Nmap من Kali Linux ضد DC-Test ولدت Windows تصفية منصة events مع Event ID 5156. كان نشاط الشبكة مرئيًا في نظام التشغيل ولكنه لم ينتج عنه في البداية مطابقة Wazuh alert. عملت agent; a project-specific.

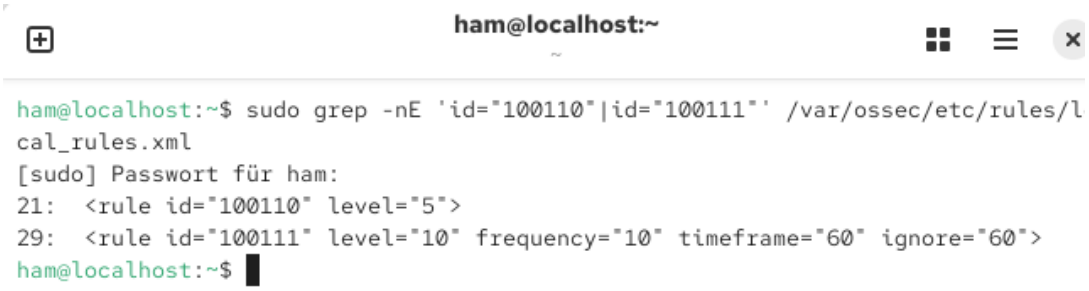
Rule logic غير صالح

Rule	وظيفة	نتيجة
100110	يعترف مطابقة 5156 events من مصدر كالي المعروف 192.168.20.7.	واحد event, level 5
100111	يتوافق مع الزيارات المتعددة لـ rule الأساسي ضمن نافذة الوقت المحددة.	Scan alert, level 10 alertn
MITRE T1046 (باللغة الإنجليزية).	يرتب السلوك Network Service Discovery.	سياق المحلل

تم التحقق من صحة rules مع wazuh-analysed -t ؛ انتهى الاختبار برمز الخروج 0. كان alert عبارة عن true positive ، ولكن بسبب الاختبار المختبري المعتمد لم تقع حادثة.



الشكل 7: ذات الصلة *Nmap alert* من *rule 100111* إلى *level 10*



الشكل 8: التحقق بنجاح من صحة *rules* المحلية

نصيحة الإنتاج إن **Kali-IP** الصلب مناسب للاختبار المختبري القابل للتكرار ، ولكن ليس كمنتج عام **scan** **detectionn**. يتطلب **rule** المنتج معايير سلوكية واستثناءات واختبارات **false positive**.

8. تقوية Ubuntu وقبول المخاطر

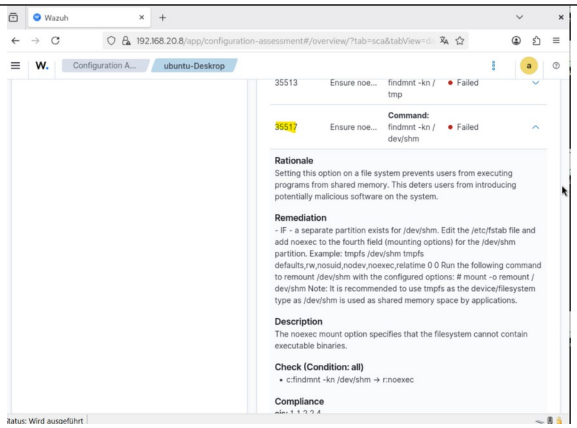
تحسين قيمة السلامة دون تشويه وظيفة النظام

التقييم SCA

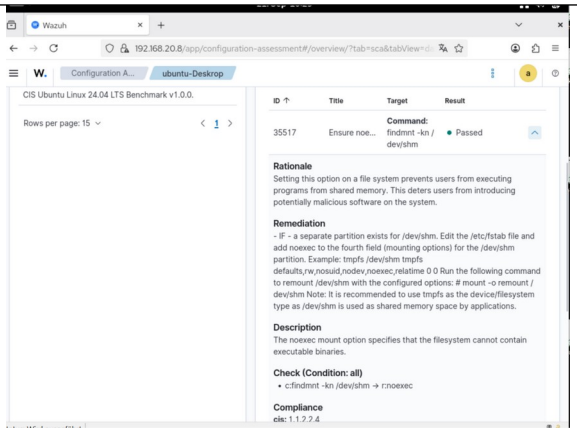
تم تقييم سياسة Wazuh-SCA-policy المستندة إلى رابطة الدول المستقلة في Ubuntu. كانت القيمة الأساسية 50 في المئة. تم تعميق اختبارين تقنيًا: 35517 لخيارات التثبيت لـ dev/shm/ و 35509 لوحدات نظام الملفات غير الضرورية.

تحقق من 35517: تصلب بنجاح

تمت إضافة خيار noexec لـ dev/shm/. بعد إعادة التثبيت وإعادة التشغيل ، يتم تأكيد الخيارات ، rw ، nosuid ، relatime ، noexec ، nodev ، nodev. تم تغيير الاختيار إلى تم تمريره وتم التحقق من persistence.



قبل: تحقق من 35517 لم يتم الوفاء بها



بعد: تحقق من 35517 مرت بعد إعادة التشغيل

تحقق من 35509: استثناء مبرر

تم حظر الوحدات غير الضرورية. ظلت FUSE نشطة لأن Ubuntu-Desktop يتطلب ذلك عبر GVFS. تم إصلاح وحدة الدهون في النواة ولا يمكن تفريغها مثل وحدة قابلة للتحميل. نظرًا لأن السياسة تتطلب جميع الشروط الفرعية ، فقد بقي الفحص العام على Failed. تم توثيق القرار على أنه risk acceptance بدلاً من تغيير السياسة فقط للحصول على نسبة أفضل.

قيمة الامتثال الأخضر ليست غاية في حد ذاتها. يجب تقييم الاعتماد الفني والتأثير التشغيلي والمخاطر **residual** معا.

9. Sysmon وEncoded PowerShell

سلسلة جديدة غير صالحة detection سلسلة في Windows-11 endpoint ham1

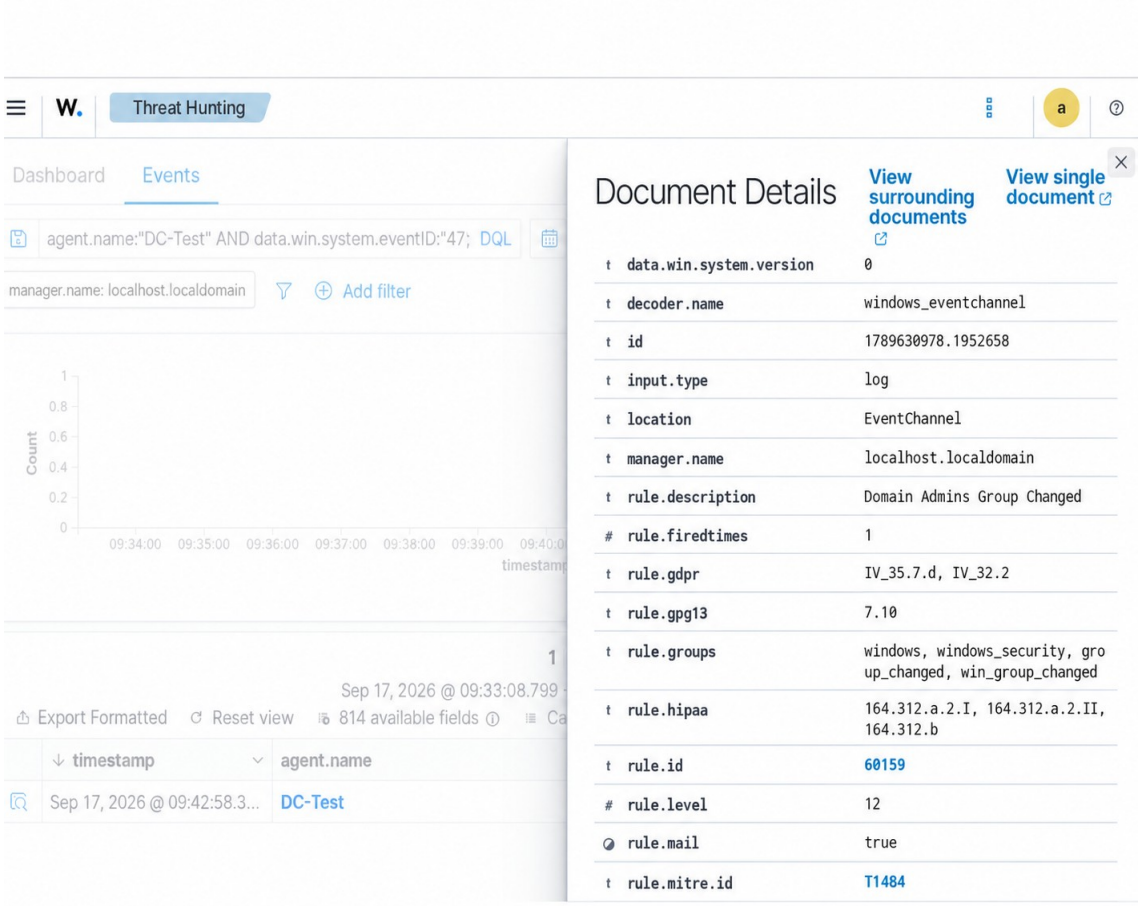
الهدف والنتيجة

في 14.10.2026, تم تثبيت Sysmon في ham1 و PowerShell تم تضمين DC-Test في Wazuh الرصد.تم إجراء اختبار detection الكامل في ham1. غير خطرة base64 ترميز PowerShell فقط صدر النص https://p7.inininininin اختبار. https://palided

نقطة الاختبار	نتيجة مؤكدة
Endpoint	ham1 / Agent 002 / 192.168.20.5
مصدر البيانات	Microsoft-Windows-Sysmon/Operational
event محلي	Sysmon Event ID 1 مع powershell.exe و EncodedCommand
MITRE تخصيص	T1059.001 – PowerShell غير صالح
Wazuh detection غير صالح	Rule 92057, level 12 غير صالح
Alert الوقت	14.10.2026, 13:21:55 م
Rule القرار	rule الحالية المستخدمة؛ لا يوجد ضعف المحلية rule التي تم إنشاؤها

تم التحقق من صحة سلسلة عدم الصلاحية processing

1. Wazuh Agent يقرأ Sysmon event القناة.
2. Sysmon Event ID 1 يحتوي على process، سطر الأوامر وعلامة MITRE.
3. manager processes event تماما ويعين إلى Agent 002.
4. المتكاملة rule 92057 يخلق alert في dashboard.
5. تم إلغاء تنشيط إجمالي JSON المفعل مؤقتًا logging بعد التحكم.



الشكل 9: *Wazuh Rule 92057 في level 12 مع MITRE T1059.001*

الأدلة التقنية

ملف Detection	المحتويات
Windows11_Sysmon_EventID1_EncodedCommand_مشفرةCommand Sysmon_EventID1	Sysmon المحلية process بداية مع ترميزCommand
Wazuh_Sysmon_EventID1_Document_Details_T1059_001 Wazuh_EventID1_Document_Details_T1059_001	مجموعة كاملة من البيانات وتعيين MITRE
Wazuh_PowerShell_encodedCommand_Rule_92057_Level12	level 12 في Dashboard alert rule 92057

Detection القرار منفصلة **rule** سيكون ممكنا من الناحية الفنية، ولكن غير ضروري من الناحية الفنية. **Wazuh** الحالية **rule** يغطي بالفعل **use case**. هذا يتجنب مزدوجة **alerts** والصيانة غير الضرورية.

10. Alert Triage و Incident Response

من ضرب إلى قرار مسبب

تشغيل Triage

1. التحقق من صحة Alert: صحيح agent ، الوقت المناسب ، event أو rule ID.
2. جمع السياق: المستخدم وعنوان المصدر والوجهة و process سطر الأوامر ومتابعة النشاط.
3. التحقق من التفويض: الاختبار المخطط ، نشاط المشرف أو نشاط غير معروف.
4. تصنيف: True Positive, False Positive, حميدة True Positive أو الحادث.
5. حدد رد الفعل: وثيقة، مزيد من الدراسة، تحتوي على أو escalate.
6. الانتهاء من التحكم: التنظيف وإعادة الاختبار والدروس المستفادة.

runbooks اختصار

نوع Alert	اختبارات هامة	رد فعل محتمل
الشبكة Scan	المصدر، منافذ الوجهة، نافذة زمنية، الموافقة، نشاط المتابعة	escalate والحد من الوصول في مصدر غير معروف
عدم التسجيل	المستخدم ، مصدر IP ، التردد ، المتابعة الناجحة	تحقق من الحساب والمصدر؛ قفل أو escalate عينات
مجموعة AD المميزة	4728/4729, الحساب التنفيذي, إطلاق التغيير	إزالة العضوية غير المصرح بها وتأمين الحساب
PowerShell / Sysmon	سطر الأوامر ، الأصل process ، المستخدم ، المضيف ، نشاط الشبكة	تحقق من سلسلة process و persistence في نشاط غير معروف
FIM	مسار, عمل, hash/Diff, المستخدم, وافق التغيير	ملف آمن ، أصل واضح ، عزل في حالة التلاعب

مثال: Nmap Alert

Rule تم تصنيف 100111 ك True Positive و Authorized Activity: المصدر 192.168.20.7 كان نظام اختبار البوتاس المعروف ، وكان الهدف DC-Test وكان من المخطط نافذة زمنية. لذلك ، لم يكن من الضروري عزل. نفس alert من مصدر غير معروف كان سيؤدي إلى إجراء تحقيق واحتواء محتمل.

11. النتائج والقيود والدروس المستفادة

إظهار القوة التقنية دون إخفاء حدود المختبر

النتائج المحققة

- المراقبة المركزية لـ Windows Server و Windows 11 و Ubuntu في SIEM المشتركة.
- معيار ناجح detections وكذلك الارتباط الذاتي المطور والمختبر للشبكة scan.
- تخصيص MITRE يمكن تتبعه لـ T1046 و T1059.001.
- قرارات المحلل الموثقة بدلاً من مجموعة alert التقنية البحتة.
- تنظيف الضوابط النهائية وإزالة كائنات الاختبار المؤقتة.

الحدود الحالية

التحسين المخطط	المعنى	الحدود
مؤشرات الأداء الرئيسية القابلة للقياس وفترات الاختبار الأطول	لا يوجد بيان حول الحمل الإنتاجي أو Betrieb-24/7	بيئة مختبرية صغيرة
في وقت لاحق ، جهاز استشعار مخصص أو منفذ التحكم مرآة في اختبار شبكة المختبر النقي.	يرى المستشعر حركة المرور إلى Ubuntu-VM ، ولكن ليس حركة مرور تبديل افتراضية كاملة.	مستشعر واحد Suricata
Sigma إضافية rules وسيناريوهات هجوم والدفاع واقعية	تم اختبار use cases المحددة فقط	محدود Detection مجموعة
النسخ الاحتياطي والاستعادة والتشغيل الوثائق	تبقى نقاط الفشل الوحيدة	لا توافر عالية
تحرير وتأمين اختيار GitHub	تحقق قبل النشر العام	لقطات الشاشة تحتوي على بيانات المختبر

الدروس المستفادة

- لم يتم بعد اعتبار detection غير صالح لـ event ؛ و detection ليس حادثًا بعد.
- في حالة عدم وجود alerts ، يجب فحص التدقيق والنقل وفك التشفير واللوائح بشكل منفصل.
- قاعدة زمنية ثابتة ، وأسماء غير صالحة فريدة من نوعها agent وعناوين مستقرة توفر الكثير من وقت التحليل.
- تحتاج إلى التحقق من الصحة والاختبارات الخاضعة للرقابة والحماية من rules مزدوجة.
- Risk Acceptance هو أفضل من تغيير مستحضرات التجميل التي تعرض العملية للخطر.

12. بنية Portfolio للتقدم إلى الوظائف

الوثائق كنقطة دخول ، والتحف الفنية بشكل منفصل ويمكن التحقق منها

هيكل GitHub أوصت

المحتويات	المسار
وصف قصير ، والهندسة المعمارية ، والنتائج الرئيسية ولقطات الشاشة	README.md
وثائق المشروع كاملة بصيغة PDF	docs/portfolio (باللغة الإنجليزية).
البراهين المختارة والمختبرة وربما المسودنة	docs/evidence (باللغة الإنجليزية).
rules المحلية 100110, 100111, 100120 و 100121 مع التفسير ومرجع الاختبار	rules/wazuhs/wazuhs rules/wazuhs
بيانات التكوين المعدلة لـ agents و Sysmon و SCA	التهيئة
runbooks قصيرة لـ scan, login, AD, PowerShell و FIM	runbooks
حالات الاختبار القابلة للتكرار ، والنتيجة المتوقعة والفعلية alert	اختبارات
تم التحقق من صحة Sigma rules مع الحالة ، detection ، logsource وملاحظة الاختبار	rules/sigmas/sigmas rules/sigmas
Suricata المحلية rules 1000001 و 1000002 بما في ذلك ضبط	rules/suricatas/suricatas rules/suricatas

التعامل مع الأوامر

لا تعرض وثائق الحافظة سوى معلومات تقنية قصيرة ذات صلة بالشرح. تنتمي الأوامر والتكوينات الكاملة إلى ملفات منفصلة ومُصَغَّرة في المستودع. وبالتالي ، تظل الوثيقة قابلة للقراءة ، بينما لا يزال بإمكان القائمين بالتوظيف والمقابلات الفنية إعادة إنتاج التنفيذ.

قبل تحميل كلمات السر، يتم إزالة الرموز والبيانات الداخلية وأسماء المستخدمين غير الضرورية. يتم نشر الأوامر فقط و **rules** اختبارها في المختبر.

13. خارطة طريق التطوير

من مختبر يعمل إلى محفظة مقنعة SOC

الحالة	الهدف	المرحلة
أُنجز	DC-Test; و ham1 في Sysmon تم إنشاؤها والتحقق من صحتها Sigma rule	1. Wazuh Sysmon Sigma
أُنجز	الشبكة telemetry متكاملة, scan الكشف, انخفاض فيضان الإنذار و تم إنشاؤها Wazuh rule 100121	2. Suricata
التركيز التالي	اختبار سيناريوهات واقعية وآمنة بشكل متكرر	3. هجوم/Verteidigung
Runbook قاعدة متاحة	تحسين Triage, تحديد الأولويات, الأرقام الرئيسية ودفاتر اللعب	4. Dashboards و IR
التحضير	نشر مهنيا rules والاختبارات والبراهين والوثائق	5. محفظة GitHub
بعد ذلك	استصدار نص مشروع السيرة الذاتية وأسئلة المقابلة من المشروع	6. التطبيق

14. سجل الأدلة

الأدلة من المشروع بأكمله تقف حتى 17.10.2026

الأدلة الأساسية في الوثيقة

لا.	الأدلة
01	الهندسة المعمارية وتدفق البيانات
02	Wazuh Agents ثلاث صفحات نشطة
03	Ubuntu FIM مع تغيير المحتوى
أُنجز	ham1 في Windows Event 4625
أُنجز	Domain Admins لـ Rule 60159
التركيز التالي	Scan, Level 10 للشبكة Rule 100111
07	SCA تحقق 35517 قبل المعالجة
08	SCA تحقق 35517 بعد إعادة التشغيل مرت
09	Wazuh الخدمات النشطة
10	التحقق من صحة rules رمز الخروج 0
11	AD تمت إزالة حساب اختبار
12	Commandترميز مع Sysmon Event ID 1
13	MITRE T1059.001 تفاصيل المستند مع Wazuh
14	Wazuh Rule 92057, level 12
15	DC-Test في whoami /priv لـ Sysmon Event ID 1
16	دون أخطاء Sigma rule proc_creation_win_whomai_priv في بناء الجملة والشرط
17	قبل الضبط مع 205 Suricata TCP-SYN detection Wazuh-treffen
18	بعد الضبط مع استجابة Suricata TCP-SYN detection Wazuh
19	Wazuh Rule 100121, Level 8, MITRE T1046
20	مع اثنين من الزيارات Wazuh Dashboard: Rule 100121

مبدأ التوثيق

تظهر الأدلة نتائج ناجحة وذات صلة فقط. تم استخدام Mistry لحل المشكلات ، ولكن لم يتم اعتباره محفوظات خطوة بخطوة غير ضرورية. حيث أدى خطأ إلى تحقيق تقني مهم - على سبيل المثال ، في Nmap detection أو في SCA استثناء - يتم توثيق السبب مع الحل النهائي. gap

15. Detection Engineering باستخدام Sysmon وSigma وSuricata

Sysmon و Sigma ودمج Suricata كمصدر بيانات شبكة جديد

15-1 الهدف والنتيجة الإجمالية

يجمع هذا القسم بين مراقبة العمليات على الأجهزة، ومنطق Detection القابل للنقل، وNetwork Telemetry ضمن مسار تحليل متكامل. سجّل Sysmon تشغيل whoami /priv على DC-Test. وتم التحقق من Sigma Rule باستخدام Sigma CLI. ثُبّت Suricata على ubuntu-Desktop ودُمج مع Wazuh، ثم جرى التحقق منه باستخدام TCP SYN Scan مصرح به من Kali. خفّض Threshold Tuning عدد النتائج من 205 إلى Alert واحد. ورفعت Wazuh Rule مخصصة النتيجة إلى Level 8 وربطتها بـ MITRE T1046.

بلوك بلوك	نتيجة
Sysmon	Process Create سجلت بنجاح في DC-Test ل whoami /priv
Sigma	التحقق Rule proc_creation_win_whoami_priv.yml من الصحة من الناحية الفنية
Suricata	ICMP و TCP-SYN النشاط الكشف في eve.json
التكامل Wazuh	Suricata-JSON processed كمصدر محلي log
ضبط Alert	205 يضرب مماثلة خفضت إلى واحد alert لكل مصدر والوقت نافذة
MITRE ATT&CK	T1046 Network مع level 8 في rule 100121 نهائي Service Discovery

15.2 Sysmon و Sigma

Sysmon تم تثبيته على Windows 11 و Windows Server. للاختبار الجديد ، تم تنفيذ الأمر غير الخطير whoami /priv على DC-Test. Sysmon Event ID 1 قدمت process اسم ، سطر الأوامر الكامل ، المستخدم والوالد process. نهاية موجودة. ثم تم حفظ detection ك Sigma rule لجعل logic مفهومة وقابلة للإصدار وقابلة للتحويل في وقت لاحق إلى منصات SIEM أخرى.

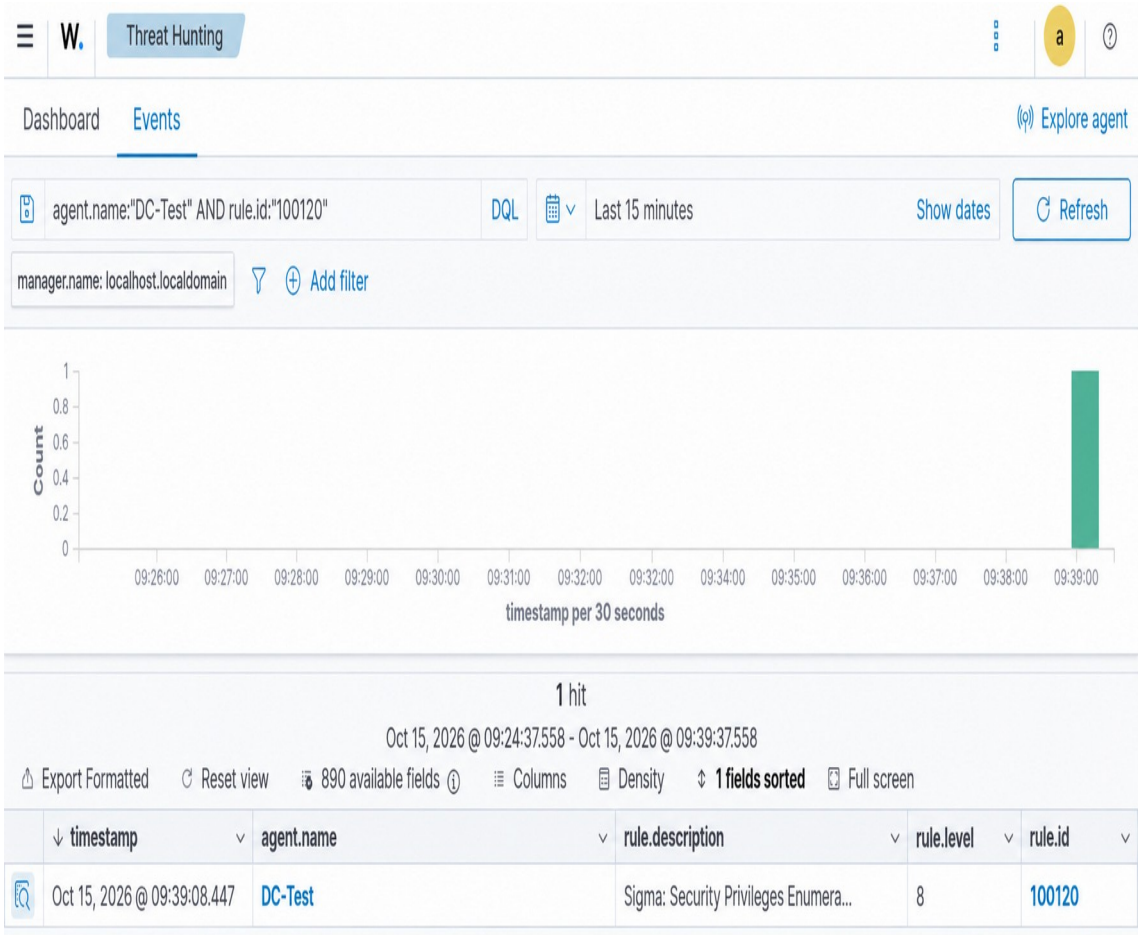
أوامر الاختبار والاختبار الهامة:

```
whoami /priv

| Get-WinEvent -LogName "Microsoft-Windows-Sysmon/Operational" -MaxEvents 10
| Where-Object {$_.Message -match "whoami.exe"}
Select-Object -First 1 TimeCreated, Id, Message

soc-portfolio/rules/sigma/proc_creation_win_whoami_priv.yml/ تحقق sigma
```

نتيجة التحقق لم يبلغ اختبار Sigma عن أخطاء rule أو أخطاء الشرط. تم تنفيذ حالة rule كتجربة لمختبر تم تطويره حديثًا rule. وبالتالي ، فإن rule نظيف تقنيًا دون تقديمه جاهزًا للإنتاج.



الشكل 10: *Wazuh Rule 100120* لـ *whoami /priv* إلى *DC-Test*

15.3 تثبيت وتكوين Suricata

تم تثبيت Suricata مباشرة على ubuntu-Desktop. تتم مراقبة eth0 بواسطة المستشعر في 192.168.20.20. اقتصرت HOME_NET على شبكة المختبرات الداخلية 192.168.20.0/24. لم يتم تغيير المضيف المادي Hyper-V ولم يتم استخدامه كهدف للهجوم.

التركيب والاختبار الأساسي:

```
sudo apt-get install software-properties-common -y
sudo add-apt-repository ppa:oisf/suricata-stable -y
sudo apt-get update
sudo apt-get install suricata jq -y

sudo suricata-update
sudo suricata -T -c /etc/suricata/suricata.yaml
sudo systemctl restart suricata
sudo systemctl is-active suricata
```

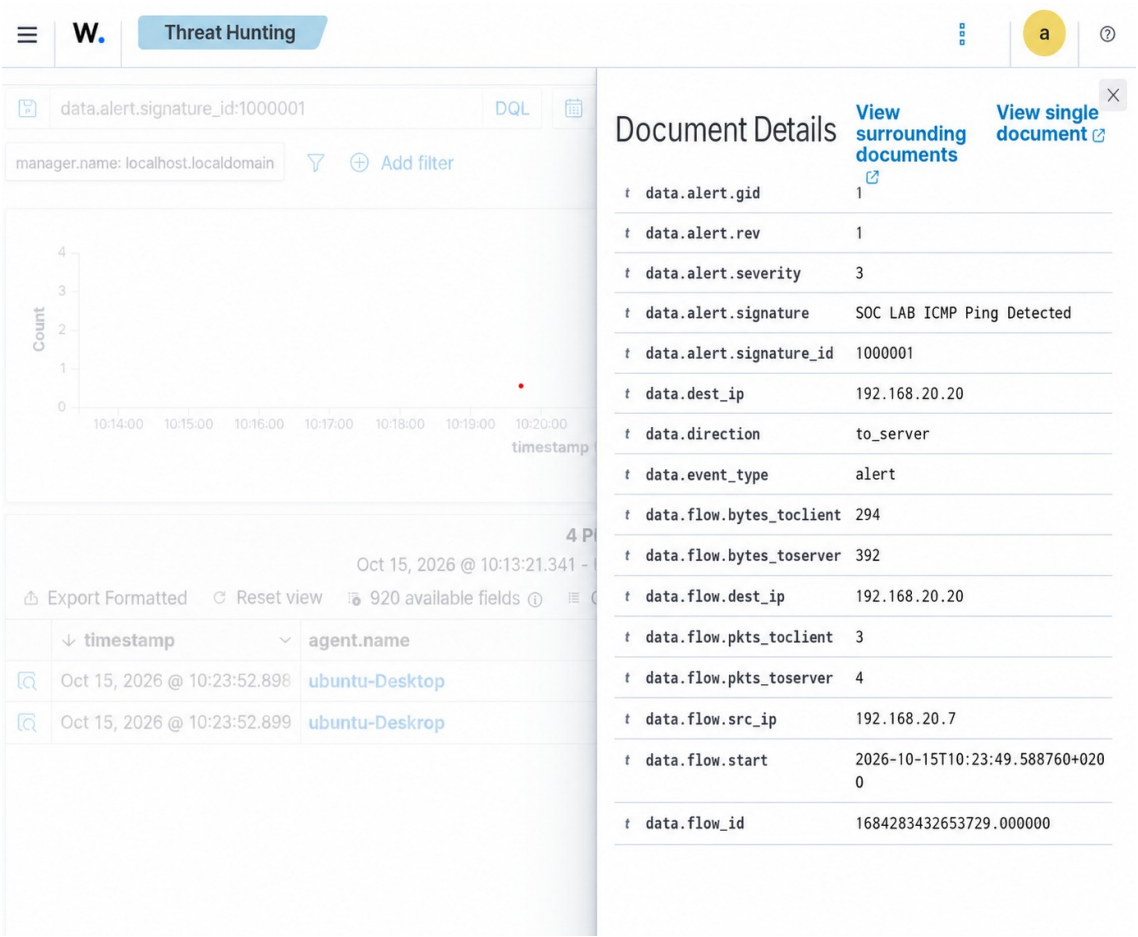
إعدادات	القيمة
الصفحة الرئيسية_NET	[192.168.20.0/24]
التقاط واجهة	إيث0
الإخراج Event	var/log/suricata/eve.json/
معيار rules	var/lib/suricata/rules/suricata.rules/
محلي rules	var/lib/suricata/rules/local.rules/

15.4 الاتصال ب Wazuh الاتصال Suricata

يقرأ Wazuh Agent ك Ubuntu JSON log المصدر. وهكذا, و Suricata الحقول مثل عنوان المصدر, عنوان الوجهة, signature ID, signature النص و Severity تبقى قابلة للبحث بطريقة منظمة.

```
<localfile>
<log_format>json</log_format>
<location>/var/log/suricata/eve.json</location>
<localfile/>

sudo systemctl restart wazuh-agent
sudo systemctl is-active wazuh-agent
```



الشكل 11: *Suricata ICMP SID 1000001 منظم في Wazuh*

15.5 محلي Suricataity rules والاختبارات التي تسيطر عليها

أولاً ، أكد ICMP rule مع SID 1000001 أن التقاط الحزمة ، Suricata التحليل و Wazuh عمل إعادة التوجيه. ل scan-use case ، SID https://p9.in ثم تم إنشاء.

```
alert icmp أي -> 192.168.20.20 أي (msg:"SOC LAB ICMP Ping Detected"; itype:8; sid:1000001; rev:1;)

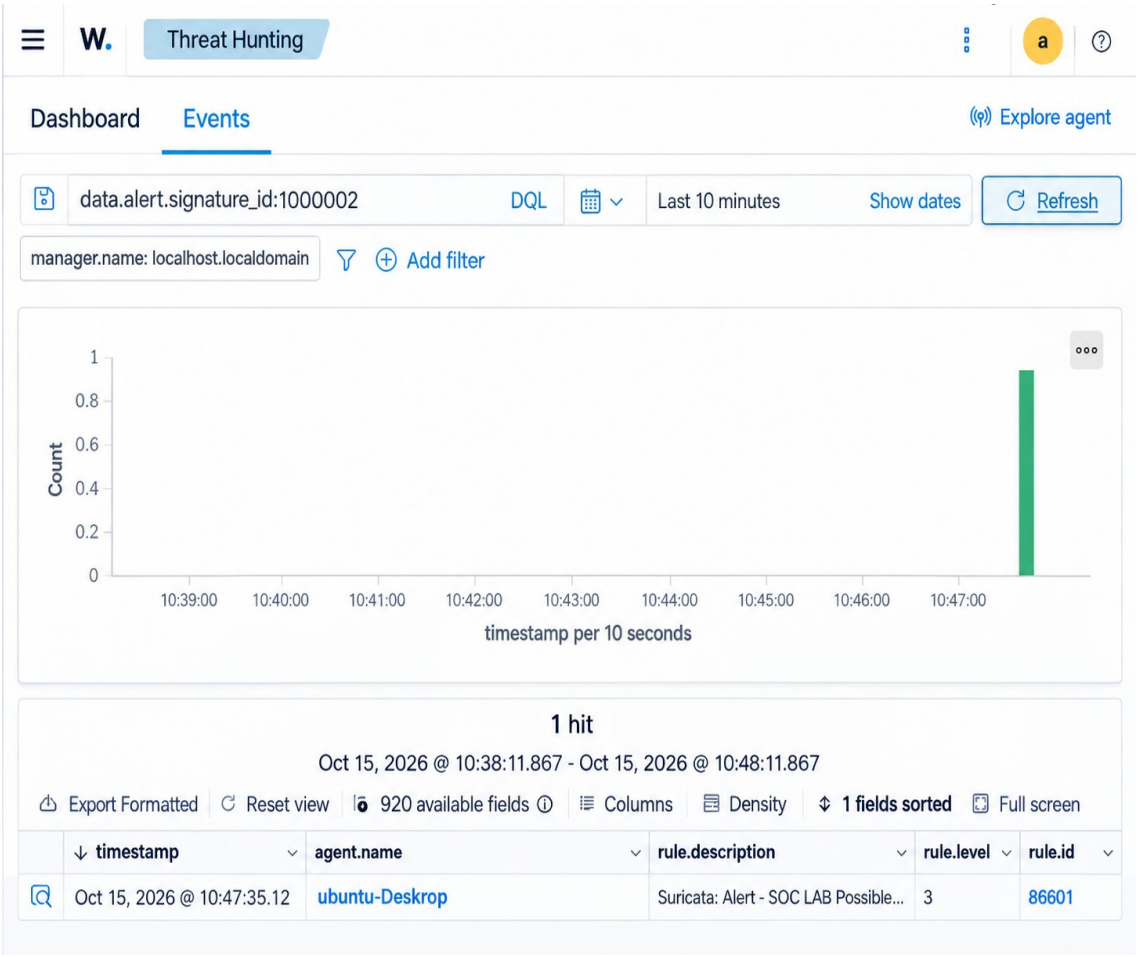
alert tcp أي -> 192.168.20.20 أي (msg:"SOC LAB ممكن TCP SYN ميناء "Scan"; الأعلام:S; التدفق:عديمة الحالة; العتبة: اكتب على حد سواء, المسار by_src, العد 20, ثانية 10; صنف:-attemped recon. https:
```

اختبار معتمد ل Kali Linux:

```
sudo nmap -sS -Pn -T3 -p 1-1000 192.168.20.20
```

تحقق من الموقع Ubuntu:

```
sudo jq -c 'select(.event_type=="alert" and .alert.signature_id==1000002) | {timestamp,src_ip,dest_ip,dest_port,signature_id:.alert.signature_id,signature:.alert.signature,severity:.alert.severity}' /var/log/suricata/eve.json | tail -n 5
```



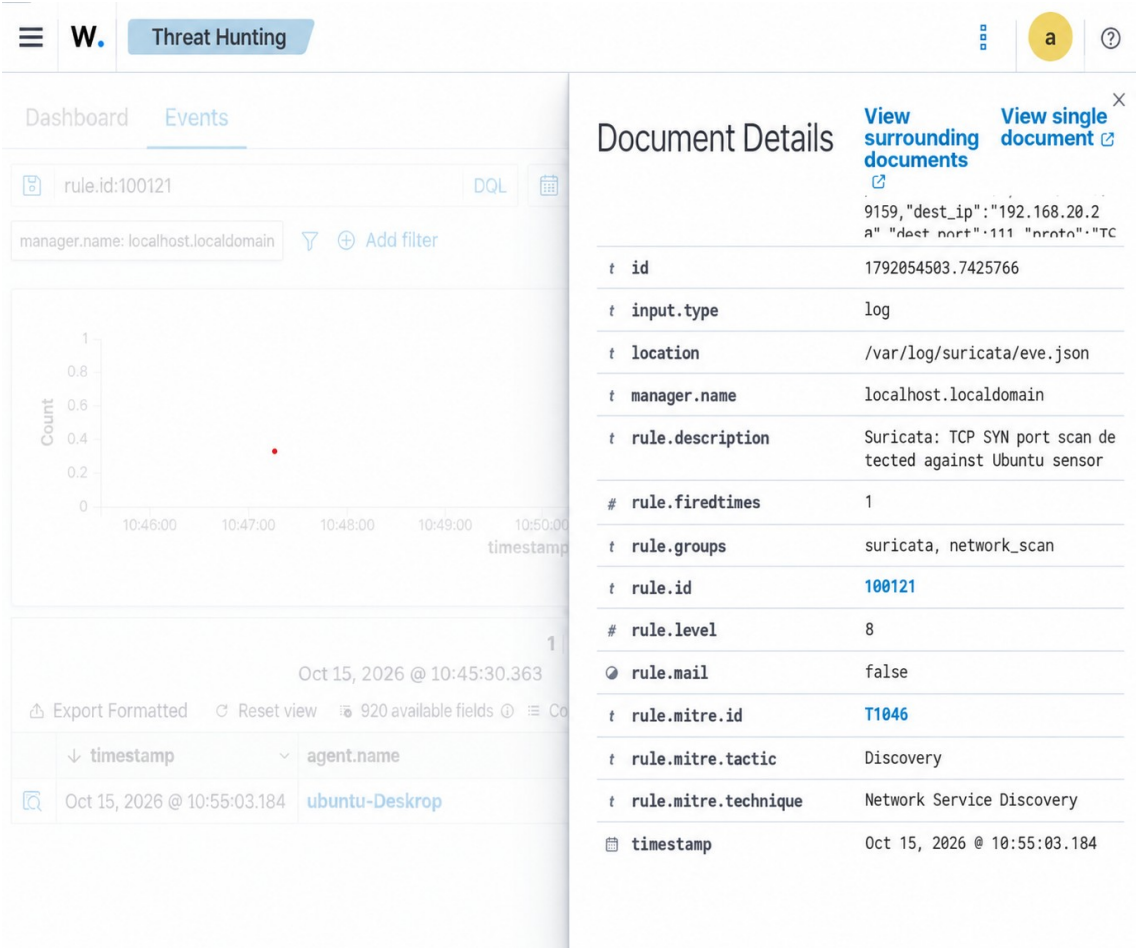
الشكل 12: بعد الضبط ، نتيجة *Wazuh* لـ *Suricata SID 1000002* بقايا.

15.6 تعيين Wazuh rule وMITRE

scan use case, بالنسبة للمشروع المحدد .Level 3 alert في البداية ولدت Rule 86601 86601 العامة Suricata .Wazuh Rule https://p9.inin

```
<",group name="suricata,network_scan>
<"rule id="100121" level="8>
<if_sid>86601</if_sid>
<field name="alert.signature_id">^1000002$</field>
<description>Suricata: TCP SYN port scan detected against Ubuntu sensor</description>
<mitre><id>T1046</id></mitre>
<rule/>
<group/>

sudo /var/ossec/bin/wazuh-analysisd -t
sudo systemctl restart wazuh-manager
sudo systemctl is-active wazuh-manager
```



الشكل 13: النهاية *Wazuh Rule 100121* في *level 8* مع *MITRE T1046*

15-7 تقييم المحللين والمرحلة التالية

وalert هو True Positive لأن TCP SYN sca حدث فعلا. وكان أيضا نشاط مختبري معتمد وبالتالي ليس حادثا. خلال Triage, المصدر 192.168.20.7, الهدف 192.168.20.20, signature 1000002, نافذة الوقت, https://p10in.

المراحل الكاملة 3 و 4 تجمع دراسات الحالة الموثقة بين الاختبارات الخاضعة للرقابة ، alert ، telemetry ، التصنيف و triage ، incident response القرارات. يتم التركيز على النشر المنظم كملف GitHub.

15.8 Alert تحليل على Wazuh rule 100121

في 16.10.2026 ، تم البحث عن وحدة threat hunting في dashboard rule.id:100121. للفترة المرئية "آخر 30 يومًا" ، أظهر العرض اثنين من alert events. أظهرت قائمة event ضربة من 15.10.2026 في 10:55 وواحد من 16:20.20 في 10:55

تم فتح المشاهدات التفصيلية المؤكدة https://p0.20غير صالح ubuntu-Desktop أقدم من ubuntu-Desktop (ID 003, 192.168.20.20) ممكن Suricata SOC SOC LAB ,192.168.20.20 الهدف ,Kali 192.168.20.7 المصدر. هذا يعني أن اثنين من الوثائق alert متوفرة لتدفق مختلف. TCP SYN Port https://p10p10.inininin.in.in.in.in هذا لا يمكن أن يختتم بأمان لمدة اثنين من منفصلة scanning يعمل. أظهر حقل data.alert.action أن كلا التفاصيل مسموح بها: Suricata حركة المرور المعترف بها ، ولكن لم يمنعها.

طابع زمني	المصدر الهدف	TCP المنفذ المستهدف	الإجراء المتخذ
15.10.2026 10:55:03.184	(كالي) 192.168.20.7 192.168.20.20 (Ubuntu)	111	مسموح - الكشف ، غير محظور
16.10.2026 08:32:09.683	(كالي) 192.168.20.7 192.168.20.20 (Ubuntu)	199	مسموح - الكشف ، غير محظور

ينتمي كل من alerts إلى Suricata SID 1000002 و Wazuh-rule 100121 (level 8). يثبت المستندان alert تدفقات مختلفة ، ولكن ليس بالضرورة أن يكون هناك مستندان منفصلان scans.

التقييم: Detection كان ناجحا. عرض الصفر alerts من level 12 وما فوق متوافق مع Rule Level 8 ولا يعني فشل detection. بسبب الاختبار المختبري المعتمد ، يكون التصنيف True Positive - اختبار الأمان المعتمد ؛ لم يكن مطلوبًا الاحتواء.

16. دراسة حالة SOC: فحص TCP SYN باستخدام Suricata

من SYN الخاضعة للرقابة scan إلى قرار المحلل الموثق

16.1 الهدف و procedure

تقوم دراسة الحالة هذه بتحويل الشبكة المصادق عليها بالفعل detection إلى سير عمل كامل SOC. تم اكتشاف كالي معتمد TCP-SYN scan بواسطة Suricata ، منظم إلى Wazuh ، مرتبط بـ MITRE ATT&CK ثم triagated. بقي الاختبار بالكامل داخل شبكة المختبر المعزولة https://p7in.in.

Nmap -> Suricata SID 1000002 -> eve.json -> Wazuh Rule -> MITR T1046 -> سلسلة كالي **Detection** <- **Triage** الإغلاق.

16-2 بيانات الحالة

الميدان	التقييم
معرف الحالة	SOC-2026-001
العنوان	شبكة Discovery الكشف عن من كالي
المصدر	Kali Linux - 192.168.20.7
الهدف	الاستشعار Ubuntu / Suricata - 192.168.20.20
اختبار اختبار	sudo nmap -sS -Pn -p 1-1000 --reason

الميدان	التقييم
	192.168.20.20
Suricata	Scan ميناء TCP SYN ممكن SID 1000002 - SOC LAB
Wazuh	Rule 100121, level 8 غير صالح
MITRE ATT&CK	T1046 - Network Service Discovery
التصنيف	اختبار الأمان المعتمد - True Positives
الحالة	مغلق
الاستعلام Dashboard	rule.id:100121; آخر 30 يوم: 2 alert events (15. و 16.10.2026); المنافذ المستهدفة 111 و 199.
إجراء Suricata	مسموح؛ لم يتم حظر حركة المرور المكتشفة

16.3 Triage وقرار المحلل

1. تحقق من صحة alert: rule ID, Severity, الطابع الزمني, عنوان المصدر والوجهة وكذلك Suricata signature تم التحقق منها.
2. المصدر: 192.168.20.7 هو نظام البوتاس المعروف لمختبر الاختبار المعزول.
3. لتحديد النطاق: تم توجيه scan حصريًا ضد 192.168.20.20 والموانئ من 1 إلى 1000.
4. تحقق من السياق: تتطابق معلمات الوقت و scanning مع الاختبار المصرح به.
5. تحقق من النشاط المصاحب: لم يكن هناك دليل إضافي على الاستغلال ، persistence أو تدفق البيانات.
6. البت: Detection صحيح من الناحية الفنية وبالتالي true positive؛ الاختبار المختبري المؤكد ليس حادثًا أمنيًا.

تقييم المحلل **TCP-SYN scan** حدث بالفعل وتم اكتشافه بشكل صحيح. نظرًا لأن مصدر الاختبار وهدفه ونافذة الوقت والغرض من الاختبار معروفين ومعتمدين ، تم إغلاق **alert** ك **True Positive** - اختبار أمان معتمد. سيكون **false positive** خاطئًا من الناحية الفنية لأن السلوك المبلغ عنه حقيقي.

16.4 Incident Response Runbook غير صالح

المرحلة	محلل عمل	معيار أو نتيجة **Escaation**
1. يصادق	تأكيد alert الحقول والطوابع الزمنية و rules و signature ومصدر البيانات.	إرجاع بيانات غير صالحة أو غير كاملة للاختبار الفني.
2- النطاق	تحديد المصدر والوجهة ونطاق المنفذ والتردد وغيرها من alerts من نفس المصدر.	زيادة الأولوية للأهداف المتعددة أو النشاط المتكرر.
إنريتش	تحقق من دور الأصول أو المالك أو التغيير أو إصدار الاختبار والمعروف scanners.	تعامل مع مصدر غير معروف أو عدم الإفراج عن مشبوهة.

المرحلة	محلل عمل	معيار أو نتيجة Escaation
4. تصنيف	تعيين True Positives, False Positives, أو أذن حميدة True Positives.	Escalate كحادث محتمل مع دافع غير معروف.
5. تحتوي على	في حالة وجود scan غير مصرح به، قم بعزل أو حظر مصدر ومراقبة الأنظمة المتأثرة.	وفي الاختبار المختبري المؤكد، لم يكن هناك حاجة إلى الاحتواء.
6. إغلاق	توثيق القرار والأدلة والتدابير والتحسينات بطريقة مفهومة.	وضع الحالة مغلقة مع التبرير والإشارة إلى الأدلة.

16-5 الإنجاز والتحسينات

بالنسبة لعملية إنتاجية ، فإن نفس detection سوف يتم توثيقها في scalate في مصدر غير معروف أو أنظمة مستهدفة متعددة أو نشاط استغلال إضافي. ضبط العتبة المنفذة بالفعل يقلل من alert التكرارات دون إغفال scan الفعلية. الشكل 12 لنتائج الضبط والشكل 13 للتعيين النهائي https://p5.in.inin Wazuh تحتوي على دليلين غير صالحين مع MIT.

إغلاق ملاحظة مختبر معتمد **scan** أكد. **Detection** عملت على النحو المصمم. لا توجد مؤشرات حل وسط محددة. لا الاحتواء مطلوب. أغلقت القضية.

17. دراسة حالة SOC: Encoded PowerShell

من Sysmon telemetry إلى قرار الحادث المستند إلى السياق

17.1 الهدف و procedure

تستخدم دراسة الحالة هذه اختبار EncodedComd الذي تم تنفيذه بنجاح بالفعل على Windows 11. Sysmon تم التقاط سلسلة process وخط الأوامر الكامل. Wazuh اعترف السلوك المشفر Base64 PowerShell مع rule المتكاملة 92057 وتم تعيينه إلى MITRE ATT&CK chase.

Windows 11 ham1 -> PowerShell EncodedCommand -> Sysmon Event ID 1 -> سلسلة **Detection** الإغلاق. <- **Wazuh Rule 92057 -> MITRE T1059.001**

17-2 بيانات الحالة

الميدان	التقييم
معرف الحالة	SOC-2026-002
العنوان	تم اكتشاف PowerShell مشفر على Windows 11
Endpoint	ham1 - Windows 11, 192.168.20.5
سياق المستخدم	إجراء اختبار مختبري محلي معتمد
مصدر البيانات	Microsoft-Windows-Sysmon/Operational, Event ID 1 غير صالح
ميزة Detection	powershell.exe مع محتوى -EncodedCommand و Base64
Wazuh	Rule 92057, level 12 غير صالح
MITRE ATT&CK	T1059.001 - PowerShell
التصنيف	اختبار الأمان المعتمد - True Positives
الحالة	مغلق

17.3 Triage وقرار المحلل

1. التحقق من صحة alert: تحقق من المضيف والمستخدم والطابع الزمني و rule ID و level و MITRE.
2. تحقق من سلسلة process: تقييم الصورة والصورة الأبوية وخط الأوامر والمستخدم قيد التشغيل من Sysmon Event ID 1.
3. فك ترميزCommand: فك تشفير محتوى Base64 دون اتصال كـ Unicode وتقييم الأمر الفعلي PowerShell دون إعادة تشغيله.
4. تحديد النطاق: ابحث عن نفس سطر الأوامر ونفس المستخدم و alerts قابلة للمقارنة لمزيد من endpoints.
5. تحقق من النشاط المصاحب: فحص اتصالات الشبكة ، والطفل processes ، وتغييرات الملفات ، و persistence ، والوصول إلى بيانات الاعتماد في نافذة الوقت.
6. اتخاذ القرار: تم اعتماد أمر الاختبار وآمن ؛ detection صحيح ، ولكن لا يوجد حادث أمني.

تصنيف المحلل ترميز **PowerShell** هي ميزة مشبوهة قوية ، ولكن لا يوجد دليل على نشاط ضار من تلقاء نفسه. في هذه الحالة ، أكد المضيف والوقت وسياق المستخدم والمحتوى المفكك الاختبار المختبري المعتمد. لذلك تم إغلاق **alert** كـ **True Positive** - اختبار أمان معتمد.

17.4 Incident Response Runbook غير صالح

المرحلة	محلل عمل	معيار أو نتيجة **Escaation**
1. يصادق	Wazuh و Sysmon الحقول وكذلك اكتمال تأكيد CommandLine.	توفير مفقود telemetry للمستشعر أو agent اختبار.
2. فك بأمان	فك تشفير محتوى Base64 دون اتصال ؛ لا تقم بتنفيذ المحتوى دون تحديد.	تحميل, obfuscation, الوصول إلى بيانات الاعتماد أو persistence على الفور escalate.
3- النطاق	العثور على نفس الأوامر والمستخدمين والمضيفين والتجزئة والمتابعة processes في نافذة الوقت.	يزيد تعدد endpoints أو تكرار executions من الأولوية والنطاق.
4. إثراء	تحقق من نقد الأصول ودور المستخدم وتغيير أو اختبار المشاركة.	معاملة المستخدم غير معروف أو الإفراج في عداد المفقودين كحادث.
5. تحتوي على	عزل المضيف مع النشاط الخبيثة المؤكدة، ووقف process والتحف آمنة.	في الاختبار المصرح به ، لم يكن هناك حاجة إلى الاحتواء.
6. إغلاق	وثيقة فك شفرة المحتوى والقرار والأدلة والتدابير.	مغلق كـ True Positive مع الإشارة إلى الشكل 9.

17-5 الإنجاز والتحسينات

في بيئة الإنتاج ، فإن نفس detection سوف يقوم على الفور بإيداع scalate في المستخدمين غير المعروفين أو المحتوى المشبوه الذي تم فك تشفيره أو اتصالات الشبكة الخارجية أو المتابعة processees. ويستند القرار ليس فقط على alert الاسم ، ولكن على process السياق ، ومحتوى فك التشفير ، والأنشطة المرتبطة. الشكل 9 وثائق https://p5in.in.

إغلاق ملاحظة معتمد مشفرة **PowerShell** اختبار المختبر أكد. **Sysmon telemetry** و **Wazuh detection** عملت على النحو المصمم. كان المحتوى فك الشفرة حميدة. لا مؤشرات حل وسط تم تحديدها. أغلقت القضية.

18. دراسة حالة SOC: الحسابات والمجموعات ذات الامتيازات

Windows إخطار events والتغييرات إلى Domain Admins تقييم مشترك

18-1 ترسيم الحدود الموضوعي والتقني

تلخص دراسة الحالة الأمن المصادق عليه بالفعل Windows events في triage المشتركة use case. Event 4625 وثائق تسجيل فشل, Event 4624 تسجيل ناجح, Event 4728 إضافة عضو إلى مجموعة عالمية تمكين الأمن و Event 4729 الاختبارات المخبرة الأصلية. لذلك ، لا توجد سلسلة فارغة من الهجمات بين events ؛ يظهر كيف يربط SOC مثل هذه الإشارات مؤقتًا ومهنيًا.

سلسلة **DC-Test** الأمن **Wazuh Windows** -> **Log** أجهزة فك التشفير و **rules** <- المصادقة **Detection** وتحليل تغيير المجموعة <- **Triage** -> **MITRE T1098.007** <- الإغلاق.

18-2 بيانات الحالة

التقييم	الميدان
SOC-2026-003	معرف الحالة
تغيير عضوية غير صالح logs و Domain Admins	العنوان
المجال ,DC-Test - Windows Server, 192.168.20.2 test.local	نظام
عدم التسجيل	Event 4625 غير صالح
التطبيق الناجح	Event 4624 غير صالح
عضو يضاف إلى مجموعة عالمية تمكين الأمن	Event 4728 غير صالح
عضو تمت إزالته من مجموعة عالمية مدعومة بالأمان	Event 4729 غير صالح
Rule 60159 للتغيير المرصود إلى Domain Admins	Wazuh
T1098.007 - Additional Local or Domain Groups	MITRE ATT&CK
اختبار إداري معتمد - True Positives	التصنيف
مغلق	الحالة

18.3 Triage وقرار المحلل

1. التحقق من صحة events: الكمبيوتر ، الطابع الزمني ، event ID ، حساب التداول ، حساب الوجهة وعنوان المصدر.
2. تقييم logins: تحقق من سبب الخطأ 4625 ، رمز الحالة ، نوع وتردد logon ؛ تأكيد مع 4624 logon نوع ومصدر الجهاز.
3. تنفيذ الارتباط بحذر: فقط مع المستخدمين المناسبين والمصادر والوقت windows تفترض وجود اتصال بين 4625 و 4624.
4. التحقيق في تغيير المجموعة: تحقق من حساب التداول 4728 و 4729 ، العضو المتأثر والمجموعة المستهدفة Domain Admins.

5. التحقق من التفويض: تأكيد تغيير التخليص ومسؤولية المسؤول والغرض من عضوية المجموعة.
6. تحديد النطاق: ابحث عن مزيد من التغييرات في الحساب ، و logons المميزة والإجراءات المتطابقة على وحدة تحكم المجال.
7. اتخاذ القرار: تم تنفيذ الإجراءات loged بالفعل ، ولكن تمت الموافقة على الاختبارات المعملية ؛ لا توجد حادثة أمنية.

تصنيف المحلل **events** هي **true positives** لأنه تم تسجيل **logins** وتغييرات المجموعة بالقيم الحقيقية. تم إجراء التصنيف كاختبار إداري معتمد فقط بعد التحقق من المستخدمين والتوقيت والمجموعة المستهدفة وسياق الاختبار. يمكن أن يشير 4625 **events** المتكررة إلى القوة الغاشمة ، ولكن لا يتم تصنيفها على أنها **MITR T1110** فقط بسبب محاولة خطأ واحدة.

18.4 Incident Response Runbook غير صالح

المرحلة	محلل عمل	معيار أو نتيجة **Escaation**
1. يصادق	تأكيد event ID ، المضيف ، المستخدم ، المصدر ، الوقت و Wazuh rule.	توضيح حقول غير مكتملة أو انحرافات زمنية.
الموصول	قم بتوصيل 4625 و 4624 و 4728 و 4729 فقط باستخدام الحقول والوقت المطابقين windows.	لا تقم بإنشاء سلسلة من الهجمات من events التي تكون مستقلة عن الوقت.
3. التحقق من التغيير	لحن domain admins تغيير مع تغيير تقاسم والمسؤول.	escalate الإصدار المفقود فورا كأولوية عالية.
4- النطاق	ابحث عن logons المميزة الأخرى ، وتغييرات الحساب والمجموعة بالإضافة إلى الأنظمة المتأثرة.	الحسابات أو الأنظمة المتعددة توسع نطاق الحوادث.
5. تحتوي على	إزالة الأعضاء إذا كان غير مصرح به، قفل الحساب والتحقق من الجلسات.	وفي الاختبار المختبري المؤكد، لم يكن هناك حاجة إلى الاحتواء.
6. استرداد	التحقق من صحة الأذونات أو إعادة تعيين كلمات المرور أو الرموز إذا لزم الأمر وزيادة المراقبة.	العملية العادية فقط بعد تأكيد اختبار الإذن.
أغلق	توثيق الأدلة والتفويض والقرارات والتدابير بطريقة مفهومة.	مغلق كـ True Positive.

18-5 الإنجاز والتحسينات

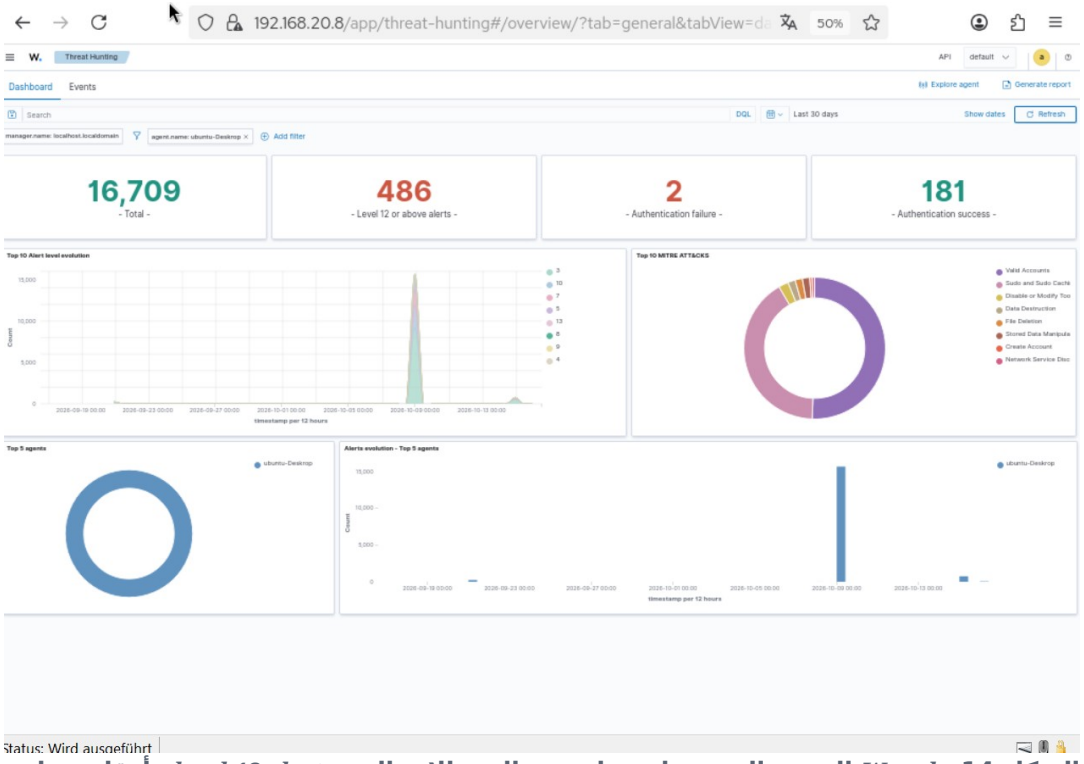
بالنسبة لعملية إنتاجية ، يجب مقارنة التغييرات التي تطرأ على المجموعات ذات الامتيازات العالية على الفور ببيانات التغيير والمسؤول المسؤول وغيرها من login events. من المهم بشكل خاص الفصل بين الأنشطة المترابطة فعليًا والمشاهدين بشكل مشترك فقط events. هذا يحافظ على التحليل استنساخ وتجنب الاستنتاجات التي لم تحل.

إغلاق ملاحظة المصادقة المعتمدة و **Domain Admins** اختبارات العضوية المؤكدة. **Windows** الأمن **events** و **Wazuh detection** عملت على النحو المصمم. لا يوجد تغيير امتياز غير مصرح به أو مؤشرات حل وسط محددة. أغلقت القضية.

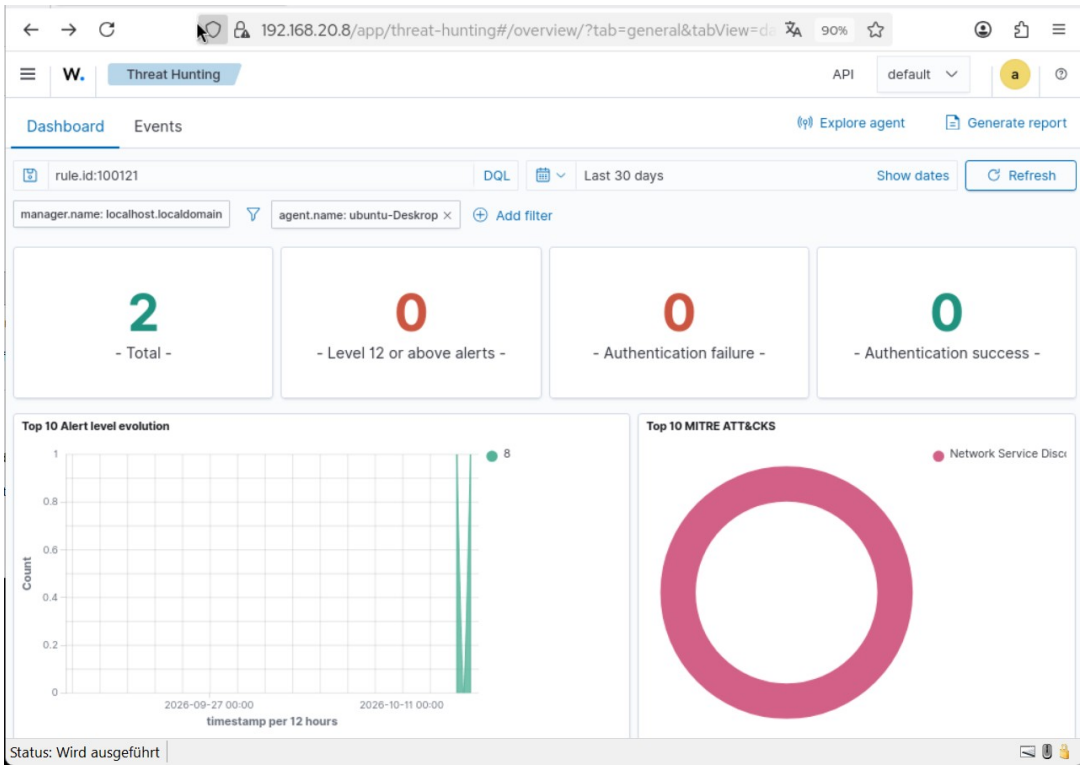
19. نظرة عامة على Dashboards وطريقة العرض

Wazuh نظرة عامة، وجهات النظر التنبيه المركزة و SOC dashboard

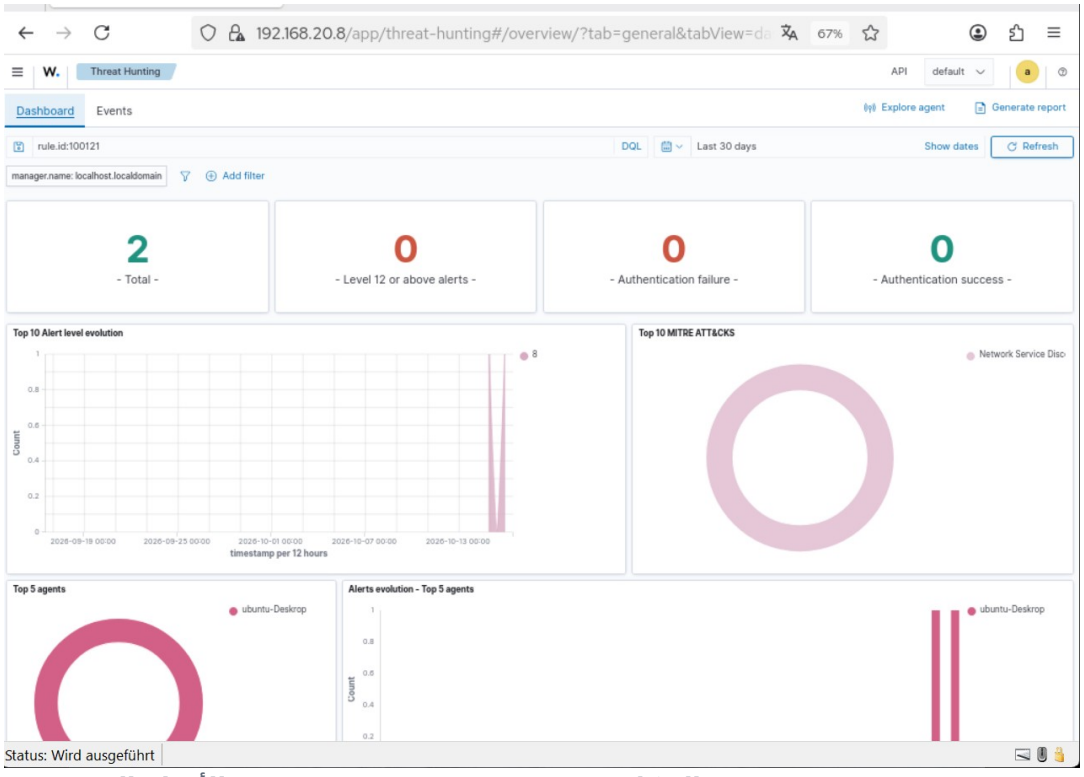
لقطات التالية وثيقة dashboard وجهات النظر للاستعراض اليومي وtriage المستهدفة. عرض العام يظهر الأرقام الرئيسية وتوزيع الوقت. مرشح على Rule 100121 يضيق البحث إلى اثنين القبض alerts; عرض مفصل يظهر فحص Suricata الحقول. المخزنة https://p6.inin غير صالح الوقت حزمة مجلس نظرة عامة كذلك



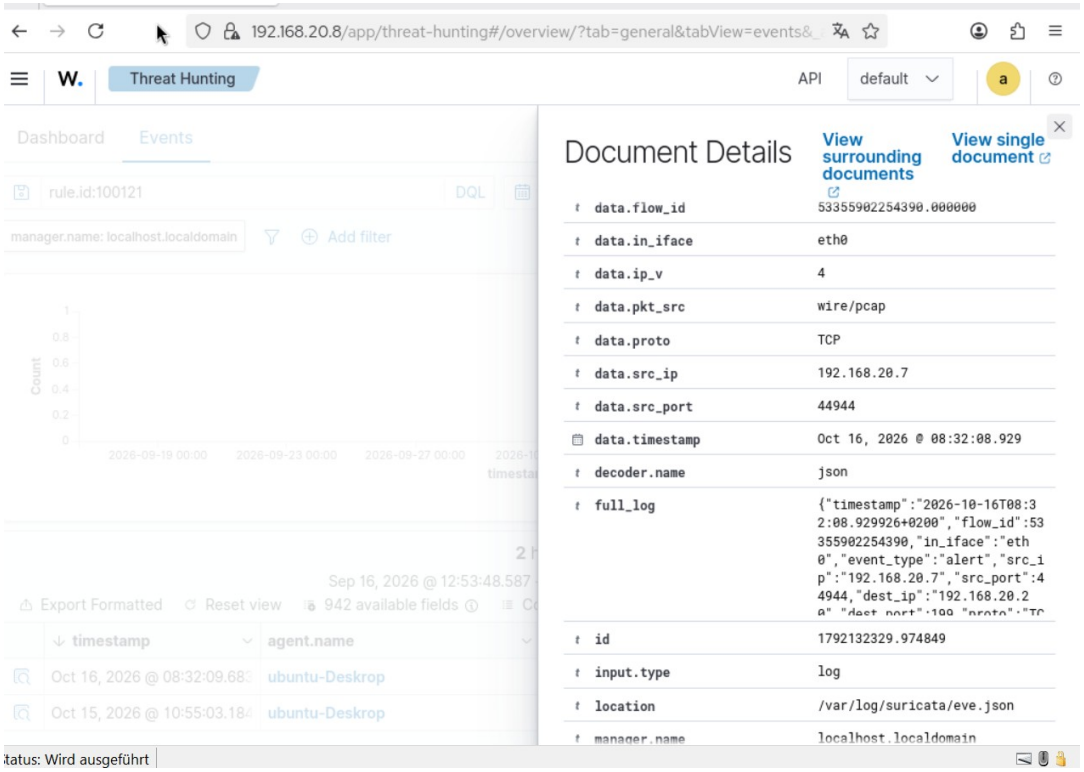
الشكل 14: *Wazuh* التهديد الصيد نظرة عامة مع العدد الإجمالي, *level-12 alerts* وأرقام مفاتيح المصادقة



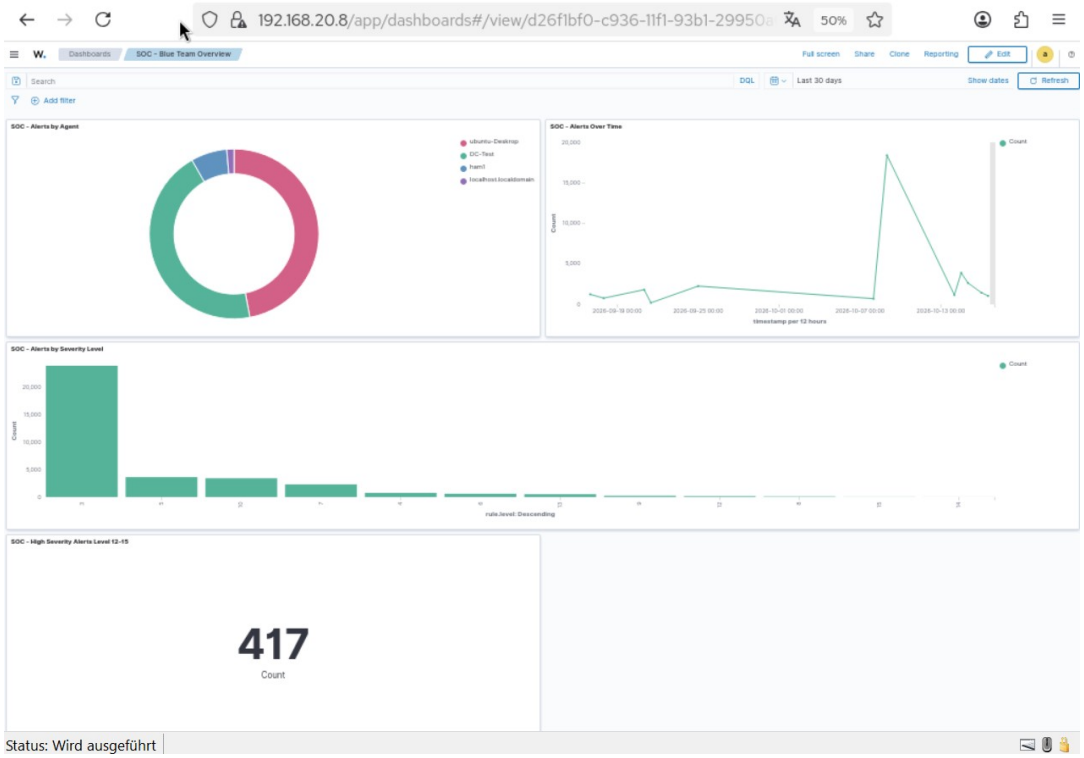
الشكل 15: *Dashboard* مع *Rule-ID 100121* واثنين وجدت *alerts*



الشكل 16: تصفية *Rule-100121* عرض مع الأرقام الرئيسية وتوزيع *alert*



الشكل 17: حقول التفاصيل لـ *Suricata-TCP-SYN scan alert* في *Wazuh*

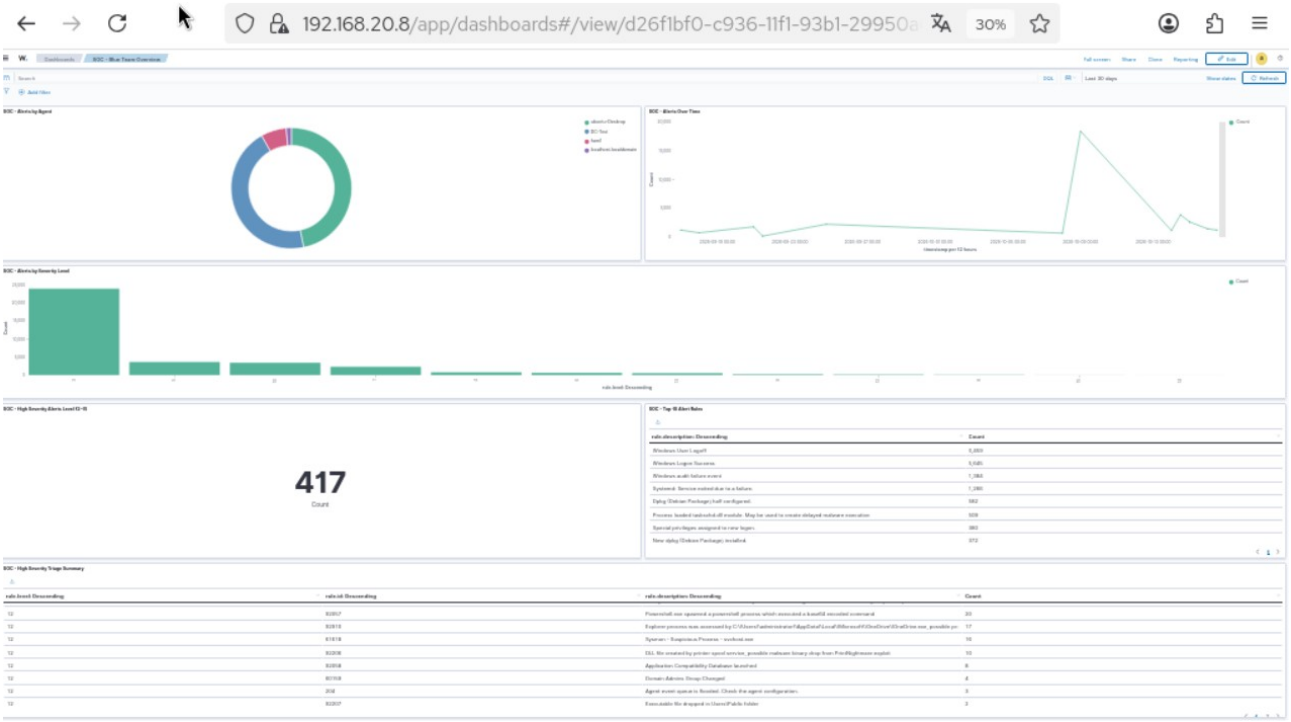


الشكل 18: مخزنة *SOC* نظرة عامة المجلس مع *agent*, الوقت و *Severity* التقييم و 417 *alerts* من *levels 12* إلى 15

Dashboard نتيجة التحسين غير صالحة يتم حفظ اللوحة ويستخدم الفترة "آخر 30 يومًا". القيمة الإضافية **"SOC - عالية Severity Alerts Level 12-15"** تعرض 417 أولوية **alerts** وتدعم الاختيار السريع لـ **events** ذات الصلة لـ **https://p7.in** غير صالح.

19.1 الأولوية Triage نظرة عامة

تم تمديد لوحة النظرة العامة SOC بواسطة تقييمين للعدد اليومي alert triage. الجدول "SOC - أعلى 10 Alert Rules" يظهر أكثر من تسبب rules. الجدول أدناه "SOC - High https://p8.inin



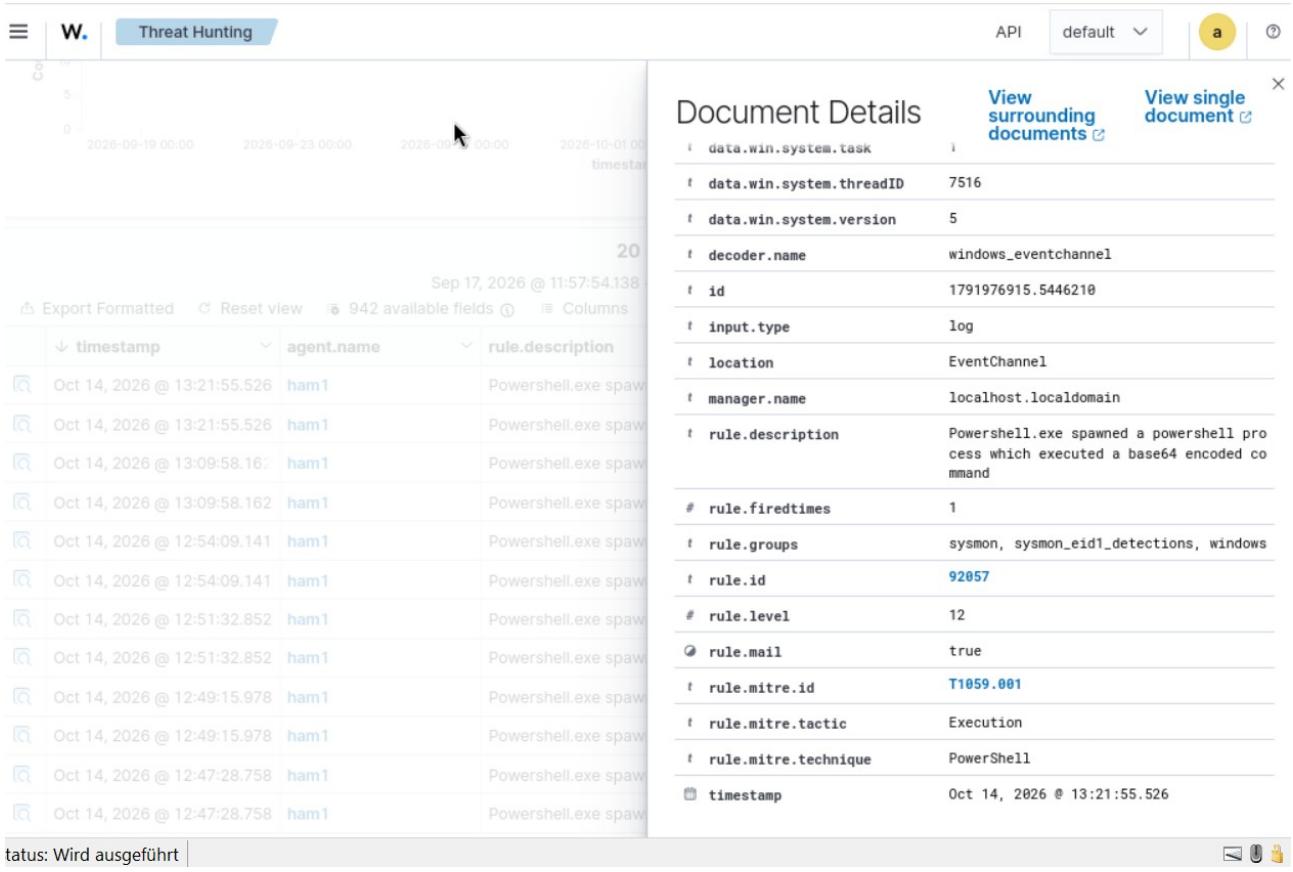
الشكل 19: مخزنة *SOC dashboard* مع أعلى 10 *rules* وأولوية *triage* ملخص ل *alerts* من *levels 12* إلى 15

نتيجة التحسين غير صالحة نتيجة العرض المشترك يسمح بتحديد الأولويات بسرعة: **Triage** علامات **Rule level** يجعل التحقيق استنساخه, يوفر الوصف السياق التقني ويسلط الضوء على العد كثيرا ما **severity, Rule ID** تحدث **alerts**. وهكذا, يمكن للمحلل تحديد لافتة للنظر **rules** ثم فحصها في **https://p6.in**

19.2 Triage من PowerShell alert

تمت مراجعة Alert سابق عالي الخطورة على ham1 Endpoint ضمن Threat Hunting وعلى مستوى Event.
لم يكن الهدف إعادة تنفيذ الاختبار، بل تقييم Detection سبق توثيقه والتحقق من سياقه ونتيجته.

نقطة الاختبار	النتائج التي توصل إليها
المستخدم / Endpoint	اختبارالمسؤول / ham1
مصدر البيانات	الخلق Sysmon Event ID 1 - Process
غير صالح Wazuh detection	غير صالح Rule ID 92057, level 12
أقر process	المشفر Base64 مع الأمر PowerShell
محتوى مفكك	اكتب الإخراج "SOC test"
MITRE ATT&CK	T1059.001 - PowerShell; Tactics: Execution
التقييم	اختبار معتمد - True Positives
رد فعل	لا الاحتواء المطلوبة؛ مغلقة تحليليا مع تبرير



الشكل 20: *Wazuh-Triage دليل ل rule 92057 مع level 12, MITRE ATT&CK T1059.001 و tactics Execution*

القرار **Triage** هو **event true positive** ، لأن **PowerShell** المشفرة **process** تم تنفيذها بالفعل والكشف عنها بشكل صحيح بواسطة **Sysmon** و **Wazuh**. ومع ذلك ، كان المحتوى الذي تم فك تشفيره اختبارًا مختبريًا غير ضار ومأذونًا به مسبقًا. لا يوجد دليل على وجود حل وسط أو **unhttps://p7.in7**. لذلك لا توجد تدابير عزل ولا غير صالحة.

ملاحظة الإغلاق معتمد **PowerShell Base64** اختبار أكد على **Sysmon Event ID 1** و **endpoint ham1. Wazuh** الكشف عن النشاط كما هو مصمم. كان المحتوى فك ترميز كتابة الإخراج **Rule 92057 (Level 12)** اختبار "**https://p9.nnot9.in**".

19.3 Triage من شبكة Suricataalert

تم فحص Suricata الموثقة بالفعل alert باعتبارها حالة triage الثانية في الشبكة level. وكان الأساس هو الزيارات إلى Rule 100121 وكذلك dashboard و event التفاصيل الموضحة في الأشكال 15 إلى 17. لم يتم تنفيذ scaedn جديد.

نقطة الاختبار	النتائج التي توصل إليها
التاريخ	16.10.2026، تقريبا. 08:32
المصدر	كالي - 192.168.20.7
الهدف	Ubuntu - 192.168.20.20
هدف الشبكة	TCP منفذ 199
غير Suricata signature صالح	Scan ميناء TCP SYN ممكن SOC LAB
تقييم Suricataity	Severity 2; الإجراء: مسموح به
غير صالح Wazuh detection	غير صالح Rule ID 100121, level 8
MITRE ATT&CK	T1046 - Network Service Discovery
التقييم	Scan الشبكة المعتمدة - True Positives
رد فعل	لا الاحتواء المطلوبة؛ مغلقة تحليليا

تم إنشاء نشاط الشبكة بالفعل وتم التعرف عليه بشكل صحيح من قبل **Suricata** كميناء **TCP-SYN** محتمل **scan**. المضيف المصدر 192.168.20.7 هو نظام البوتاس المعروف للمختبر المعزول. الهدف والتوقيت يتفقان مع اختبار الأمان المصرح به **detection**. وبالتالي ، فإن **alert** ليست **https://p6in**.

تأثير المستشعر: يؤكد إجراء القيمة المسموح به تشغيل **IDS: Suricata** تم اكتشافه و **loged** حركة المرور ولكن لم يمنع ذلك. يتوافق هذا السلوك مع وظيفة المراقبة المقصودة للمختبر.

ملاحظة الإغلاق معتمد **TCP SYN scan** من كالي 192.168.20.7 إلى **Ubuntu 192.168.20.20** أكد. **Suricata** و **Wazuh Rule 100121** الكشف عن النشاط كما هو مصمم. لا يوجد مصدر غير مصرح به أو حل وسط أو شرط احتواء محدد.

19.4 Triage من تغيير Domain Admins

نظرًا لأن الحالة الثالثة Triage ، تم التحقيق في تغيير مجموعة متميز على وحدة تحكم المجال DC-Test. تم تقييم alert الحالية إلى Rule 60159 على مدى فترة ثلاثة أشهر ؛ كان ما مجموعه أربعة زيارات متاحة. تم تحليل أحدث event. لم يتم إجراء أي تغيير جديد في Active Directoryid.

نقطة الاختبار	النتائج التي توصل إليها
التاريخ	09:52:38 ,17.09.2026 صباحا
نظام	وحدة تحكم المجال - DC-Test
Windows event غير صالح	تمت إزالة عضو من مجموعة الأمان - Event ID 4729
الحساب المعني	SOC Rule Test
مجموعة الامتياز	Domain Admins
الحساب المنفذ Executing Account	مدير البرنامج
Wazuh detection غير صالح	Rule ID 60159, level 12 غير صالح
MITRE ATT&CK	T1098.007 - Additional Local or Domain Groups
Tactics	Persistence; Privilege Escalation
التقييم	التغيير الإداري المعتمد - True Positives
رد فعل	لا الاحتواء المطلوبة؛ مغلقة تحليليا

تقييم المحلل كانت إزالة الحساب **SOC Rule Test** من المجموعة **Domain Admins** في الواقع **loged** ومعترف بها بشكل صحيح على أنها عالية **severity alert** بواسطة **Wazuh**. مدير الحساب الجاري والغرض والوقت يتفقان مع الاختبار المختبري المصرح به. لذلك ، فإن **event** هو **true positive** ، ولكن لا يشكل

استجابة التغيير غير المصرح بها في بيئة الإنتاج ، سيتم التحقق من عضوية المجموعة على الفور وإعادة تعيينها إلى الحالة التي تم إصدارها. بالإضافة إلى ذلك ، يجب فحص حساب المسؤول والتغييرات المميزة الأخرى و **sociated login events**.

ملاحظة الإغلاق إزالة مصرح بها من **SOC Rule Test** من **Domain Admins** أكد على **DC-Test. Windows Event ID 4729** و **Wazuh Rule (Level 12)** الكشف عن التغيير كما هو مصمم. لم يتم تحديد أي تعديل امتياز غير مصرح به أو شرط الاحتواء.

19.5 الزي الرسمي SOC-Triage-Runbook

يُعد هذا المعيار runbook معيارًا لـ processing لـ Wazuh alert في مختبر الفريق الأزرق. ينطبق على endpoint والشبكة و active directory events ويضمن التحقق من صحة كل alert وتقييمها ومعالجتها وإغلاقها بطريقة مفهومة.

تسلسل قياسي

لا.	المرحلة	خطوات الاختبار والوثائق
1	سجل alert	تاريخ, Agent/System, Rule ID, Alert level والوصف.
2	التحقق التقني	تحقق من raw event: Event ID, signature, الأمر, المستخدم, المصدر, الوجهة, المنفذ والبروتوكول - اعتمادا على نوع alert.
3	تحقق من السياق	تطابق مع خطة الاختبار ، وتغيير نافذة والشخص المسؤول. لا تشك في التفويض ، ولكن اثبت ذلك.
4	تحديد النطاق	ابحث عن المتجاورة alerts, المضيفين أو الحسابات الأخرى, التكرار وقرب الوقت.
5	تقييم المخاطر	MITRE technology و tactics ، أهمية الأصل ، Wazuh level والآثار المحتملة.
6	تصنيفات	حادثة أمنية, True Positives - Authorized Activity, True Positives مطلوب. False Positives or Inclusive / Escaation
7	رد الفعل	وثيقة وإغلاق في حالة authorized activity. آمنة ، تحتوي على أدلة في حالة وقوع حادث ، وإبلاغ السلطة المختصة والشروع في مزيد من التحليل.
8	اكتمل	توثيق النتيجة بالكامل، والتبرير، والتدابير، والمحلل، وختم الوقت ومذكرة الإغلاق.

معايير إلغاء الصلاحية Escaation

- Alert level 12 أو أعلى أو يتأثر نظام حرج بشكل خاص.
- تم تغيير الحسابات أو المجموعات المميزة مثل Domain Admins.
- قيادة مشفرة أو واضحة بشكل آخر غير مصرح بها بوضوح.
- المصدر غير معروف ، النشاط يتكرر أو يؤثر على عدة أنظمة.
- هناك مؤشرات على نجاح persistence ، execution ، توسيع الحقوق أو تدفق البيانات.
- لا يمكن إثبات التفويض بشكل موثوق.

التطبيق إلى use cases موثقة

Use Case	Detection	التصنيف	مقرر
PowerShell	Rule 92057 / Level 12 غير صالح	True Positives - Authorized Activity	لا احتواء؛ موثقة ومغلقة
غير Suricata portscan صالح	Rule 100121 / Level 8	True Positives - Authorized Activity	لا احتواء؛ موثقة ومغلقة
Domain Admins	Rule 60159 / Level 12 غير صالح	True Positives - Authorized Activity	لا احتواء؛ موثقة ومغلقة

نوع رد فعل المبدأ التوجيهي Alert

القطاع	اختبار ابتدائي	رد فعل محتمل على unauthorized activity
Endpoint	شجرة Process, المستخدم, سطر الأوامر, Sysmon Event ID	عزل المضيف ، والتحقيق في process ، أدلة آمنة والتحقق من الحساب.
شبكة	المصدر والوجهة والميناء والبروتوكول والتردد وأهداف أخرى	قم بحظر المصدر أو تقسيمه ، وتحقق من الأهداف المتأثرة وحركة المرور الآمنة.
Active Directory	Event ID، الحساب التنفيذي، الحساب المستهدف وتغيير المجموعة	إعادة تعيين التغيير المميز أو قفل أو إعادة تعيين الحساب والتحقق من وجود مزيد من التغييرات الإعلانية.

ملاحظة إغلاق قابلة لإعادة الاستخدام

تم التحقق من صحة [النظام] على أساس [**Events/Beweis**]. تم تقييم النشاط على أنه [تصنيف] لأنه [سبب]. التدابير المنفذة: [تدابير أو عدم الاحتواء مطلوب]. تم إغلاق القضية أو **escaated** في [تحليل]. في [تحليل]. في [تحليل]. في [تحليل].

نتيجة يجمع **Runbook** بين الثلاثة التي تم تحليلها بنجاح **use cases** مع **SOC** موحدة وقابلة لإعادة الاستخدام **process**. وهكذا ، فإن قرارات **triage** في المشروع متسقة ويمكن التحقق منها وتوثيقها لمحفظة.

19.6 Incident response تشغيل في PowerShell

procedure التالية تنقل الزي الموحد triage runbook إلى PowerShell المصادق عليها بالفعل alert. تم إنشاء event بواسطة اختبار مختبري معتمد ولم يكن حادثًا أمنيًا حقيقيًا. لذلك تم توثيق incident response التدابير كسيناريو قرص تسيطر عليها. لم يتم حظر أي حسابات إنتاجية ولم يتم عزل أي نظام.

الحالة

نقطة الاختبار	النتائج التي توصل إليها
النظام المعني	ham1 - Windows 11 Endpoint
المستخدمين	المديرTEST
Detection	Wazuh Rule 92057, level 12; Sysmon Event ID 1
الأمر الملاحظ	PowerShell with EncodedCommand; المحتوى الذي تم فك تشفيره: اكتب الإخراج "SOC test"
MITRE ATT&CK	T1059.001 - PowerShell; Tactics: Execution
نتيجة غير صالحة Triage	True Positives - Authorized Activity
حالة الحادث	لم تقع حادثة حقيقية؛ تم توثيق الاستجابة على منضدية

مراحل Incident Response

المرحلة	Procedure في السيناريو	نتيجة/evidence
1. التحضير	Wazuh agent, Sysmon process detection rule الرصد ومتكاملة يتم تنشيط. يتم تعريف المسؤولية ومصادر الأدلة و triage runbook.	Endpoint telemetry و processing processing متاح.
2. Detection والتحليل	Alert, Sysmon Event ID 1, المستخدم و سطر الأوامر. فك ترميزCommand, تطابق مع خطة الاختبار والبحث عن متابعة events.	تم تأكيد الاختبار المعتمد؛ لا يوجد دليل على نشاط المتابعة.
3. الاحتواء	في حالة: unauthorized activity عزل logically endpointal, توقف المشبوهة process والحد من نشاط الحساب. لا تقم بإجراء الاحتواء في الاختبار المعملي المؤكد.	الاحتواء غير مطلوب ؛ القرار موثق.
التوظيف و social سياسة	هجوم مؤكد: إزالة البرامج النصية الخبيثة، والمهام، أو persistence، وتحديد السبب، وإعادة تعيين بيانات الوصول للخطر.	لا توجد أفعال ضارة أو persistence الكشف.
5 - الإنعاش	تحقق من حالة النظام ، Wazuh- Agent و Sysmon-Telemetry. إذا كان endpoint هو عزل حقيقي ، فقط قم بإطلاق ومراقبة endpoint بعد التحقق من الصحة.	ظل النظام يعمل ؛ telemetry عمل.
الدروس المستفادة	Detection, alert السياق وتقييم قرار رد الفعل. في المستقبل ، ستحدد الاختبارات المعتمدة بوضوح وتستخدم إغلاق مذكرة موحدة.	Detection يعمل؛ وثائق و Runbook قابلة لإعادة الاستخدام.

اتخاذ القرار و escaation logic

شرط	مقرر	قياس
تم التصريح بإجراء الاختبار بشكل	مرخص True Positives	وثيقة وثيقة وقريبة تحليليا

واضح؛ لا يوجد نشاط متابعة		
التفويض غير واضح أو أمر غير معروف	شامل	escalate إلى المسؤولين ؛ أدلة آمنة
مصدر غير معروف أو محتوى ضار أو نشاط لاحق	حادث أمني	عزل Endpoint; فحص الحساب, process شجرة وغيرها من المضيفين
Detection غير صحيح تقنيا أو السلوك الطبيعي المتوقع	False positives	تحقق من سياق rule وإجراء الضبط فقط بعد الإثبات

الأدلة التي يجب تأمينها

- Wazuh alert with Rule ID, Level, Agent, ختم الوقت وكامل event السياق.
- Sysmon Event ID 1 مع process, الأصل process, المستخدم وكامل سطر الأوامر.
- فك تشفير PowerShell المحتوى والمقارنة يمكن التحقق منها مع خطة الاختبار المعتمدة.
- alerts و process events في نافذة الوقت ذات الصلة.
- قرار المحلل والتدابير والشخص المسؤول وتاريخ الإغلاق.

التواصل والانتهاء

في حالة وقوع حادث حقيقي ، يتم إبلاغ مالكي الحوادث والنظام **Managers**. يتم تسجيل الحالة والمخاطر والأصول المتأثرة والتدابير التي تم تنفيذها بالفعل بطريقة موجزة ويمكن التحقق منها.

Closure Note: اكتشفت **Wazuh Rule 92057** (**Level 12**) أمر **PowerShell** مشفراً على **ham1** من خلال **Sysmon Event ID 1**. وبعد فك الترميز ظهر الأمر **"Write-Output "SOC-Test** وتطابق مع الاختبار المخبري المصرح به. لم يظهر نشاط ضار لاحق أو **Persistence** أو حاجة إلى **Containment**. صُنّف **Alert** على أنه **True Positive – Authorized Activity** وأُغلق تحليلياً.

نتيجة لا يظهر **Use Case** الاعتراف التقني فحسب ، بل أيضًا **incident response** صنع القرار **process**. يتم فصل التدابير الحقيقية والمحاكاة فقط بوضوح ؛ هذا يحافظ على وثائق المشروع صحيحة من الناحية الفنية.

20. MITRE ATT&CK وأنواع Events

يوضح هذا المرجع المصطلحات المستخدمة في المشروع. وهو يشرح الفئات والمعرّفات فقط، ولا يُعد إجراء اختبار إضافياً.

بنية MITRE ATT&CK

المصطلح	المعنى
Tactic	الهدف العام للمهاجم، مثل Execution أو Discovery أو Persistence أو Privilege Escalation.
Technique	توضح كيفية تحقيق هدف معيّن؛ ويكون المعرّف بصيغة Txxxx، مثل T1046.
Sub-technique	شكل أكثر تحديداً من Technique؛ ويكون المعرّف بصيغة Txxxx.xxx، مثل T1059.001.
Procedure	تطبيق عملي محدد تمت ملاحظته لـ Technique بواسطة مجموعة أو برنامج أو نشاط.
Mapping	ربط تحليلي للسلوك المرصود، ولا يغني عن التحقق التقني من Event.

أنواع Events والمعرّفات

النوع	مثال في المشروع	المعنى
Windows Event ID	4729 ,4728 ,4625	نوع Event يسجله Windows داخل Log المناسب.
Sysmon Event ID	Process Create – 1	Endpoint Telemetry ينشئها Sysmon؛ ويسجل Event ID 1 عملية بدء Process.
PowerShell Event ID	Script Block Logging – 4104	Event في PowerShell Log يتضمن محتوى Script Block عند تفعيل Logging.
Suricata SID	1000002 ,1000001	معرّف Signature فريد لـ Suricata Rule، وليس Wazuh Rule ID.
Wazuh Rule ID	100121 ,60159 ,92057	معرّف Wazuh Rule التي تقيّم Event بعد فك ترميزه وقد تنشئ Alert.
Alert Level / Severity	Wazuh Level 8/12; Suricata Severity 2	أولوية خاصة بكل منتج؛ ولا يمكن مقارنة القيم بين المنتجات مباشرة.
Raw Event / Alert	Windows/Sysmon/eve.json → Wazuh Alert	Raw Event هو Telemetry، ولا ينشأ Alert إلا عند تطابق Detection Rule.

Mappings المستخدمة في المشروع: T1059.001 = PowerShell (Execution)؛ T1046 = Network Service Discovery (Discovery)؛ T1098.007 = Additional Local or Domain Groups (Persistence, Privilege Escalation).